Threat Intelligence

Threat evolution in Q3 2021

October 2021

group-ib.com

Contents

INTRODUCTION **3**

EXECUTIVE SUMMARY **4**

Targeted attacks on the financial sector 4

Financial threats 4

Ransomware 5

Threats to the government sector 6

FORECASTS FOR Q4 2021 **9**

DATA LEAKS IN Q3 2021 **10**

ADVANCED THREATS IN THE FINANCIAL SECTOR **12**

FINANCIAL THREATS **15**

Malware for Android 16

Threats and malware for PC 22

RANSOMWARE **27**

STATE-SPONSORED APTS **42**

Introduction

Every quarter Group-IB releases a report on the development of high-tech cyber-crime, featuring new tendencies, emerging trends, and predictions on the cyber-threat landscape.

The most dangerous threats have been attacks on the financial sector. This report features threats with a particular focus on Europe, Russia, the US, Canada, and Australia. This document also provides a comprehensive description of threats to governments, including targeted attacks supported by governments and significant data leaks.

To collect data and inform our clients, we analyze various botnets and malware while conducting incident response, monitoring underground forums, and accumulating information on new trends, threats, and data leaks. Every day we research thousands of compromised credentials, bank card numbers, hackers' accounts, messages, and announcements on the dark web, as well as tens of thousands of attacks, which enables us to promptly notify you of threats targeting your company and clients.

Executive summary

Targeted attacks on the financial sector

Q3 saw the following APT campaigns against financial organizations:

- Researchers discovered a new campaign by the FIN7 group targeting customers of the POS terminal provider Clearmind Technology (USA).
  The threat actors carried out a malicious mailout between late June and late July. The emails were disguised as a Windows 11 Alpha ad.
- In August, researchers at Bitdefender discovered that the FIN8 group had compromised the network of an unnamed financial organization in the US using a new backdoor called Sardonic.

Financial threats

- Flubot and Teabot are the most active Android Trojans in Europe. In addition to Europe, Flubot started attacking targets in Australia and Japan.
- Group-IB specialists analyzed two new Android banking Trojans: L0gicBankBot and Aberebot. They are both at their early testing stages. Aberebot is already being sold on underground resources and in Telegram channels. No campaigns involving these malicious programs have been detected.
- Group-IB specialists continue observing bank card JS sniffers being highly active. In Q3 2021, over 7,000 bank cards were stolen using the Worldcommerce JS sniffer family. Threat groups that use the Inter JS sniffer (which is sold on underground forums) are still active. For instance, in Q3 the threat group Inter-Group-23 stole 18,000 bank cards, while Inter-Group-3 stole over 3,000 cards. Group-IB specialists continue to record an increase in the number of infected websites as well as the number of threat groups stealing bank cards from users of online shops.
- Group-IB specialists analyzed the activities of two threat groups that conducted attacks against online shops to steal bank card details and were active in Q3 2021, namely, Inter-Group-23, which used the Inter sniffer and targeted online shops operating in North America, and Improved-ImageId, a group that used the ImageId sniffer developed by a threat actor with the username poter.
- Security specialists discovered that the Ramnit banking Trojan was still active (after a lull in the previous quarter). In September 2021, it was distributed using a document containing an exploit for CVE-2021-40444. At the moment, it is unclear what banks/countries the attack targeted.
- The Gozi banking Trojan attacked targets in Italy.
- Group-IB specialists discovered and analyzed the zLoader panel and established that users in the US (primarily), Japan, Germany, Australia, and Canada were the botnet's victims. The panel has a total of 55,000 bots; at the time of the analysis (September 2021) 1,130 of them were online.
- August saw posts about renting the new Android botnet Ermac appear on underground forums.
- The Android banking Trojan Anubis was active in the US, India, Italy, Indonesia, Pakistan, Canada, France, Brazil, and other countries. Group-IB specialists established this by analyzing one of the banking Trojan's panels.
- The mobile banking Trojan Cerberus attacked targets in Turkey and was distributed disguised as the Play Store app.
- The Android Trojan FlexNet was active in CIS (Commonwealth of Independent States) countries, but its activity can be described as low: Group-IB specialists detected fewer than 200 infected devices in Q3.
- July saw arrests of criminals linked to the Latin American banking Trojans Grandoreiro and Mekotio.

- In September, specialists at ESET described another Latin American banking Trojan, Numando. However, it has existed since 2018 and there is no information about the scale of its activity at the moment.
- Security researchers observed IcedID in campaigns that distributed the Conti ransomware. Malicious emails were in English.
- As before, Qbot attacked North America (the US and Canada).
- Group-IB specialists detected Gozi campaigns targeting Italy.
- It was discovered that Trickbot was active in Q3. It was used in operations by the TA551 group together with malware DarkVNC and Cobalt Strike. In September, a threat actor linked to developing Trickbot was arrested in South Korea.
- No new malware for attacks against POS terminals and ATMs was detected being sold on underground forums. Old malware, however, such as Winpot and Dipcash, can still be purchased.
- In July, two Belarusian nationals linked to ATM jackpotting in Europe were arrested in Poland. The amount of money stolen is €230,000 ($273,000).
- Group-IB specialists detected sporadic activity of BackSwap. The targets included Spanish banks: caixabank, bankia, bancsabadell.
- Security specialists discovered a new (fourth) version of Danabot with a modified C&C communication protocol. A new downloader component was also found. This suggests that the developers are improving their program. There was activity too: numerous malicious mailouts in English took place.

Ransomware

Ransomware has become the biggest threat out there: we receive information about major incidents on a daily basis. Currently, we see that threat groups specifically target major companies with large revenues, which allows threat actors to demand significant ransoms for decrypting data.

In total in Q3, we detected 32 active groups. The following new groups emerged: Quantum, BlackMatter, Black Byte, BlackBet, Payload, Karma Leaks, Groove, AvosLocker, El_Cometa.

This report covers only some of the incidents that have occurred.

Among major incidents, we highlight the following:

- On July 30, the LockBit group gained access to the servers of Accenture, one of the biggest consulting firms in the world, and stole over 6 TB of data. The threat actors demanded a ransom of $50 million. On August 12, the attackers threatened to publish the stolen data but did so only on August 22.
- On July 2, the REvil threat group attacked the company Kaseya. On July 3, the threat actors released a malicious update, which was distributed by Kaseya servers. This resulted in thousands of nodes in hundreds of businesses being compromised and encrypted. The compromise affected about 60 Kaseya customers, whose infrastructure the hackers used to encrypt about 800–1,500 corporate networks. The affected companies received notes with ransom demands ranging from $50,000 to $5 million (depending on whether or not the infected machines were connected to a domain). From Kaseya, the threat actors demanded a ransom of $70 million for a universal decryptor. On July 13, REvil websites and other infrastructure vanished from the Internet. On July 23, Kaseya announced it had received a universal decryptor tool.
- On August 5, a disgruntled participant of the Conti affiliate program published manuals and technical material of the group on XSS, a forum. The documents describe how to gain access to a network, move laterally, expand access, and then steal data before performing encryption. The person had a financial conflict with the owners of the affiliate program.
- BlackMatter Ransowmare emerged on July 21, 2021. There have been over 30 victims of the attackers.

- On September 20, the US farming cooperative NEW Cooperative was attacked by the BlackMatter group. The hackers demanded a ransom of $5.9 million. The victim asked the hackers why they attacked, since NEW Cooperative is considered critical infrastructure and the attack could significantly impact the public supply of grain, pork, and chicken, to which the threat actors replied that they did not care.

Threats to the government sector

Q3 2021 saw the discovery of the following APT campaigns against government organizations:

- A new group called GhostEmperor (China) was discovered. The group has attacked government entities and telecommunications companies in South-East Asia since at least July 2020.
- CNC (aka APT-C-48) hackers were active in attacking the Chinese military and education sector.
- Group-IB conducted an additional analysis of the Webdav-O malware, which was used in attacks against Russian federal executive authorities in 2020. It was found that the tool had a lot in common with the popular Trojan BlueTraveller used by the TaskMasters group (China) and had overlaps with the tools of the TA428 group (China). We believe that these two groups attacked Russian federal executive authorities in 2020 or that there is one united group made up of different units.
- DeadRinger attack: at least five major telecommunication providers in South-East Asia that serviced tens of millions of customers were hacked by the groups APT10 (China), Naikon (China), and APT27 (China).
- ITG18 (Iran) continues its activity and uses a previously unknown Android Trojan called LittleLooter.
- Another group was discovered, Lorec53. The threat actors were very active in the first half of 2021. The group carried out a number of attacks against Georgia, Ukraine, and other countries in Eastern Europe.
- Tortoiseshell (Iran) spent 18 months masquerading as an aerobics instructor in a cyber-espionage campaign designed to infect employees and contractors working in defense and aerospace.
- Bahamut mercenaries have been conducting a new cyber-espionage campaign using malware for Android. The malicious app disguises itself as the Jamaat chat app and the Muslim Youth app.
- HEXANE hackers (Iran) have been attacking IT and communication companies in Israel posing as HR managers.
- Confucius (India) used the theme of commercial spyware Pegasus by the Israeli firm NSO Group in phishing campaigns against the Pakistani military.
- The potentially new group SparklingGoblin (presumably China) targets the academic sector in East and South-East Asia, but it is also interested in the IT, media, and finance sectors. In its attacks, the group used a new backdoor called Sidewalk.
- A web tool called Tetris (linked to China) was used to exploit vulnerabilities in 58 popular websites to collect data on possible political dissidents.
- Operation Secondary Infektion remains an ongoing information operation. The operators attempted to infiltrate and influence individuals associated with or ideologically aligned to the far right in the US through attempting to fuel anti-Muslim sentiments and exacerbate COVID-19 disinformation.
- Security experts recently discovered a malicious campaign called Armor Piercer targeting government employees and military personnel in the Indian sub-continent with two commercial and commodity RAT families known as NetwireRAT and aka Ave Maria.
- A new APT group called FamousSparrow was discovered. The group has been active since at least 2019 and targets hotels, international organizations, engineering companies, and law firms worldwide. FamousSparrow's goal is believed to be cyber espionage.

- Security researchers spotted a new version of the FinSpy spyware, which can hijack and replace the Windows UEFI (Unified Extensible Firmware Interface) bootloader to infect the target machines.
- Unidentified threat actors carried out a phishing campaign against Pakistani organizations using NetwiredRC.
- Aggah (Pakistan) has been targeting the manufacturing industry in Taiwan and South Korea and improving their technique using legitimate services to host malware.
- A new variant of Android malware targeting the Middle East and used by the APT-C-23 group (Gaza) was discovered.
- Some details about the attack against the Alaska Department of Health and Social Services came to light.
- A group called DarkOxide has been discovered. It has been active since 2019 and has mostly attacked the semiconductor industry in South Asia.
- Activity of APT10 (China) targeting the telecommunications industry primarily in South-East Asia was discovered.
- APT27 (China) attacked government institutions, IT providers and telecommunications organizations in the Middle East and Central Asia.
- Infrastructure of the Donot group and Android Trojan samples disguised as legitimate applications were discovered.
- Security specialists detected attacks against Slovakia and the Czech Republic attributed to the DarkHalo group as well as the group's activity in a number of countries targeting IT companies, government and non-governmental organizations, think tanks, and financial services. Several backdoors were detected: Tomiris, which was discovered in attacks against government organizations in the CIS (Commonwealth of Independent States) in late 2020, and FoggyWeb, used since April 2021.
- The Patchwork group (India) conducts attacks against the Pakistani military.
- Three attacks by the Sidewinder group (India) targeting Myanmar, Afghanistan, and Nepal were discovered. Based on previous analyses and knowledge about Sidewinder's use of Telegram bots, another Telegram bot was discovered, to which stolen data was sent.
- The Gamaredon group (Russia) continues attacks against government entities using a tried and tested technique and a new late-stage tool called Gamaredon.ResidentDownLoader.
- New attacks by APT41 (China) dubbed Gentle-Voice and Mute-Pond were discovered. Organizations in the US, Taiwan, India, Malaysia, Hong Kong, the UK, Ireland, and Thailand fell victim. A total of 13 organizations were compromised and 80 were targeted. In addition, the attacks discovered in this quarter reveal information about the group's custom tools such as BIOPASS, StealthVector, StealthMutant, and StealthMutant.
- Attacks by the IndigoZebra (China) group against the Afghan government were discovered.
- Attacks by the Bitter group (India) against China's military, trade and energy organizations were discovered.
- Kimsuky (North Korea) continues attacking South Korea using old and new types of decoys.
- Security researchers discovered a campaign called Bandidos, which involved the Bandook RAT; it had been carried out since 2015 for espionage purposes and targeted Spanish speaking countries.
- A major campaign against South Asia, Myanmar, and the Philippines was discovered. It started in October 2020 and is likely conducted by the Mustang Panda group (China).
- Information about previously unknown malware called TinyTurla, which had been used by the Turla group (Russia) since 2020 in attacks against organizations in the US, Germany and Afghanistan, was uncovered.
- New versions of WildPressure's malware for Windows and macOS used in attacks in the Middle East were discovered.
- Additional information about the tools of the SideCopy group (Pakistan) was uncovered; updated versions of malware used in attacks against India, Afghanistan, Iran, and Jordan were discovered.

- Security researchers discovered the APT35 group's (Iran) campaign dubbed Operation SpoofedScholars that targeted experts in Middle Eastern affairs from think tanks, senior professors from well-known academic institutions, and journalists specializing in Middle Eastern coverage.
- DEV-0322 (China) used a zero-day vulnerability, CVE-2021-3521, in SolarWinds Serv-U FTP to attack organizations in the US.
- Attacks by the group APT37 (North Korea) against South Korea involving exploits, BLUELIGHT, and RokRAT were discovered. In addition, a phishing campaign pushing the Konni RAT to target Russia was discovered.
- Infrastructure and tools linked to the company SOURGUM (Israel) were discovered.
- A previously unknown South Asian group called APT-C-61 that had been active since 2020 targeting Pakistan and Bangladesh was discovered.
- The United States Department of Justice published an indictment against four Chinese nationals believed to be members of the APT40 group (China).
- PROMETHIUM (Turkey) distributed an Android Trojan through a Syrian government website.
- APT31 threat actors (China) have been using a new dropper in attacks conducted since 2021 against Mongolia, Russia, Belarus, Canada, and the US. In addition, instances of home routers being hijacked to form a proxy mesh used in attacks against France were discovered.
- Previously unknown activity of the Praying Mantis group targeting organizations in the US was discovered.
- Security researchers discovered a campaign called MeteorExpress and involving a wiper conducted against Iran's railway system. The attack has been linked to Indra, which identifies itself as a group that opposes the Iranian regime.
- An unknown group used full-fledged VBA RAT as part of their new operation targeting Russian and pro-Russia organizations.
- Lazarus (North Korea) continued its attacks against South Korea. This time the threat actors disguised their malware as Notepad++. In addition, the group carried out new phishing mailouts involving vacancies in financial organizations and aviation industry.

Forecasts for Q4 2021

- Even though major underground forums banned threads about ransomware affiliate programs, this has not significantly affected the sector's activity. We believe that ransomware will remain the primary threat to companies in terms of potential losses and impact on business processes.
- zLoader will remain one of the most dangerous banking Trojans. Attacks in North America, Japan, Australia, and Europe will continue.
- Qbot will be active in North America; Gozi will be active in Italy.
- A traditional surge in phishing/fraud mailouts related to the upcoming holidays (Christmas, New Year's Eve) is expected at the end of the year.
- We forecast that threat actors who use ransomware may carry out attacks when many employees take vacations and cannot promptly respond to security incidents.
- Flubot, Teabot, and Anubis will be the most active Android Trojans in Europe.
- Anubis will attack banking customers in North America.
- Flubot will be active in the Asia-Pacific region (Japan and Australia).
- Credit card sniffers will remain a relevant threat. Group-IB specialists continue detecting infections on many websites; we also see an increase in the number of groups that use this tool for their attacks.
- The activity of Latin American Trojans seems to be on the decline. Grandoreiro, Javali, Guildma, and BBtok were not detected in major attacks in Q3 2021. We believe that the banking Trojan market in Latin America will be gradually disappearing.

Data leaks in Q3 2021

- In August, security researcher Bob Diachenko discovered an unsecured database containing the personal data of 106 million people who traveled to Thailand in the last ten years: full names, arrival dates, gender, residency status, passport numbers, visa information, and Thai arrival card numbers. As at the end of September, the database was unavailable externally.
- In September, a private database containing over 3.8 billion registered users of the Clubhouse social networking service, was put up for sale on the underground forum Raidforums for 100,000 US dollars. This event attracted the attention of the public but it was later found that the database was fake; the seller was banned on the forum.
- In September, the database of the US web hosting provider and domain registrar Epik was leaked. The Anonymous group, which is behind the attack, published the 180-GB database containing 704 million records, which included names, emails, logs, contract data, registered domains, and even some data about customers' bank cards.
- In early August, unidentified attackers published over 800,000 files that they claim to have stolen from a server belonging to Oriflame, a Swedish skin care products manufacturer. In particular, over 25,000 scan copies of Georgian nationals' documents and more than 700,000 scan copies of Kazakhstan nationals' documents were published. The documents were in the JPG format. The threat actors later published an 809-GB archive containing over 1.5 million scans of Russian nationals' passports. The hackers say they have 4 TB of data in total (over 13 million files). In addition to citizens of Georgia, Kazakhstan and Russia, the leaked data includes copies of documents belonging to Ukrainian, UK, Chinese, and Spanish nationals. The data is thought to have been stolen as a result of a ransomware attack.
- T-Mobile, a wireless carrier, confirmed a leak of confidential information of millions of users. A hacker attack resulted in the confidential information of both former and prospective customers of the company being stolen. The data was put up for sale on an underground forum, where an anonymous threat actor offered to sell the personal data of 30 million customers of the US carrier. The unidentified individual was prepared to sell the personal data of another 70 million customers through other channels.
  T-Mobile later told the media that they were investigating a claim that information on 100 million users had been leaked. Several days later the company reported about the initial investigation results, according to which hackers had stolen the personal data of 7.8 million customers with postpaid accounts. In addition, the hackers obtained 40 million records of former or prospective customers who had previously applied for credit with T-Mobile.
- In July, before the start of the Summer Olympic Games, it came to light that the data of Tokyo 2020 ticket holders and event volunteers had been leaked. The stolen credentials could be used to log in to Olympic Games-related websites and compromise personal data such as names, addresses and bank account numbers. A Japanese official said that the data leak was "not large" and that measures were taken to prevent further spread of the compromised data.

Advanced threats in the financial sector

Threat name	Detection	Regions attacked
FIN7	2015	Global

Researchers at Anomali discovered a new campaign by the FIN7 group targeting customers of the POS terminal provider Clearmind Technology (USA).

The threat actors carried out a malicious mailout between late June and late July. The emails were disguised as a Windows 11 Alpha ad.

The attackers' objective was to install a Javascript backdoor that could steal financial information. Upon opening a Microsoft Word document, the user was asked to enable content to view the document. This action executed an obfuscated macro that delivered a variation of a JavaScript backdoor used by FIN7 since at least 2018.

Before connecting to its servers, a VBA loader extracts encrypted lists from the decoy documents and based on them runs checks:

- Searches for a domain name, specifically CLEARMIND (connection with the POS provider for US retailers and hotels)
- Attempts to identify the language used by the computer owner
- Searches for signs of a virtual environment
- Makes sure there is enough memory available (no less than 4 GB)
- Via LDAP checks for RootDSE, using which makes it possible to obtain the domain name in the Active Directory catalog to which the computer is connected

If the checks are satisfactory, the script proceeds to the function where a JavaScript file called "word_data.js," which is filled with junk data to disguise the payload, is dropped to the TEMP folder. However, if a VM or a language from a stop list (Russian, Ukrainian, Moldovan, Estonian, Serbian, Sorbian, Slovak, Slovenian) is detected, the JavaScript backdoor is not installed.

Threat name	Detection	Regions attacked
FIN8	2015	USA

In August, researchers at Bitdefender discovered that the FIN8 group had compromised the network of an unnamed financial organization in the US using a new piece of malware called Sardonic.

At the moment, the malware is being developed, but it already has the following functionality:

- System information harvesting
- Command execution on compromised devices
- A plugin system designed to load and execute further malware payloads delivered as DLLs.

During their attack against the US financial organization, the backdoor was deployed and executed onto victims' systems as part of a three-stage process using a PowerShell script, a .NET loader, and

downloader shellcode. The PowerShell script is copied manually onto compromised systems, while the loaders are delivered onto compromised devices via an automated process.

Financial threats

Malware for Android

Threat name	Detection	Regions attacked
FluBot (FakeChat, Cabassous)	January 2021	Germany Spain Netherlands Austria Switzerland Belgium UK Hungary Slovakia Czech Republic Greece Italy Bulgaria Denmark Norway Sweden Finland Australia Japan

This banking Trojan was discovered in early 2021. Its main function is to show fake login screens on top of other applications. As such, FluBot collects victims' electronic banking credentials and payment card details.

The malware is distributed through mass SMS spamming. Once the victim's device is infected, threat actors can upload the contact list to their command-and-control (C&C) server and send spam SMS messages from there. Links in the messages usually lead to hacked websites, where FluBot operators place their malware in the form of APK files.

FluBot does not have full control over the device unless the user provides it with access to the Accessibility service. If the rights are obtained, the malware can execute commands and simulate touching the screen, while remaining invisible to the owner of the device. As a result, FluBot is capable of intercepting and blocking app notifications, setting itself as the default SMS app, using USSD, making phone calls, and stealing contact lists. In addition, access to Accessibility allows the Trojan to display phishing screens over other legitimate applications.

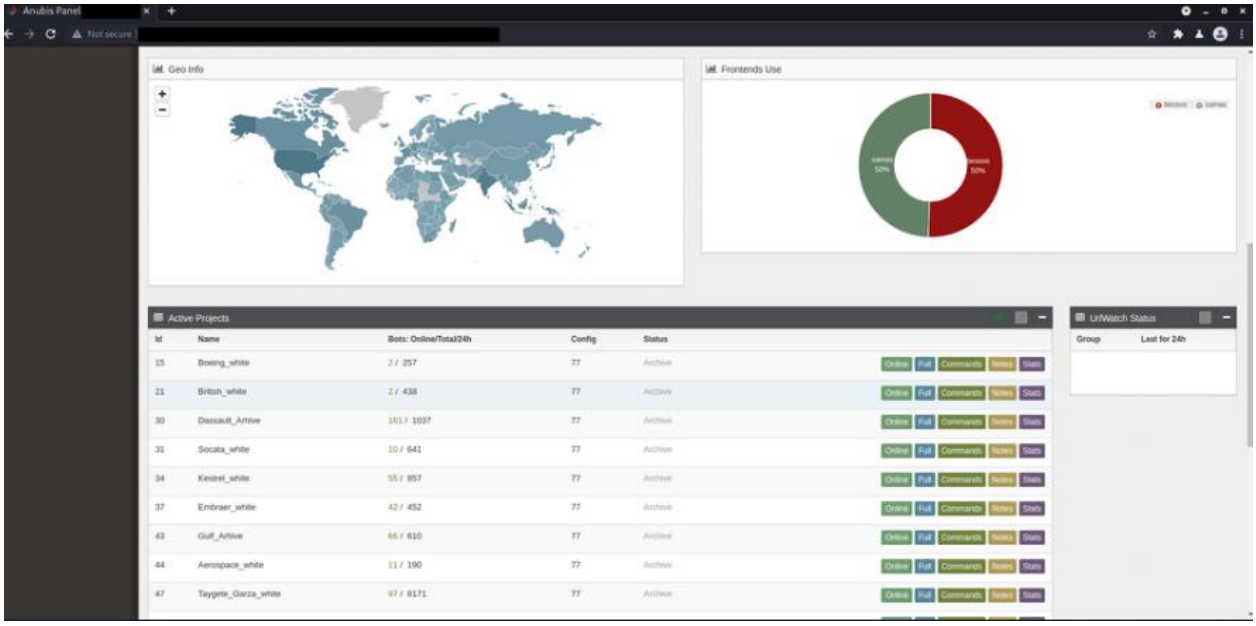
In Q1 and Q2 2021, Flubot was distributed in many European countries; this activity continues. In August 2021, instances of thousands of users in Australia being infected were discovered. In addition, there were detections in Japan.

Threat name	Detection	Regions attacked
Anubis	October 2019	USA India Italy

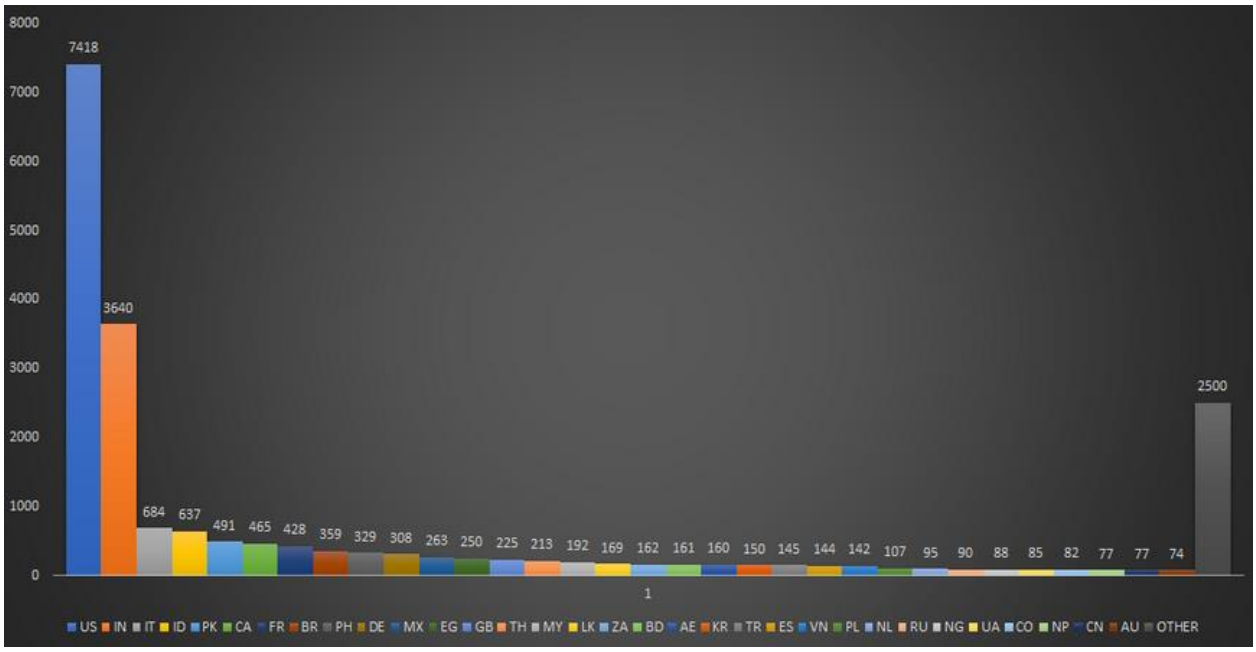
		Indonesia Pakistan Canada France Brazil

The Android banking Trojan was active in the US, India, Italy, Indonesia, Pakistan, Canada, France, Brazil, and a number of other countries. Group-IB specialists established this by analyzing one of the banking Trojan's panels, which contained a total of 20,400 unique victims.

The Anubis admin panel:



Victim statistics by country:



Anubis's main functionality includes web fakes, USSD requests, interception and sending of SMS messages, and remote access to target devices. Anubis helps obtain full control over an infected device by automatically disabling Google Protect.

Threat name	Detection	Regions attacked
TeaBot (Anatsa)	March 2021	France UK Germany Netherlands Spain Italy

The functionality of the Android banking Trojan TeaBot (Anatsa) includes intercepting SMS messages, compromising credentials, accessing screen casting, keylogging, intercepting 2FA Google Authenticator codes, and stealing money from bank accounts. Collected data is sent to threat actors' remote server every ten seconds.

In August 2021, Group-IB specialists analyzed the malware's C&C servers. A total of nine servers were studied, six of which were active at the time of the analysis. It was found that the threat actors who managed these servers were able to compromise 951 unique devices. In addition, by using this malware they were able to obtain 570 unique bank card numbers and 758 login-password pairs.

Victims include users of the following apps:

es.bancosantander.apps
es.cm.android
es.ibercaja.ibercajaapp
com.unicredit
es.lacaixa.mobile.android.newwapicon
es.liberbank.cajasturapp
com.bbva.bbvacontigo
app.wizink.es
com.kutxabank.android
com.latuabancaperandroid
es.univia.unicajamovil
posteitaliane.posteapp.appbpol
com.barclays.android.barclaysmobilebanking
uk.co.santander.santanderUK
com.rsi
com.cajasur.android
es.openbank.mobile
uk.co.hsbc.hsbcukmobilebanking
com.grppl.android.shell.halifax
com.rbs.mobile.android.natwest
com.grppl.android.shell.CMBlloydsTSB73
co.uk.Nationwide.Mobile
uk.co.tsb.newmobilebank
pt.bancobpi.mobile.fiabilizacao
wit.android.bcpBankingApp.millennium
fr.cnaf.mobile.moncompte
fr.lcl.android.customerarea
fr.creditagricole.androidapp
fr.bred.fr
posteitaliane.posteapp.apppostepay

Threat name	Detection	Regions attacked
Ermac	August 2021	Global

August saw posts about renting the new Android botnet Ermac appear on underground forums. The username of the post author, who is a Russian speaker, is also Ermac. According to the post, the malware and the panel have the following functionality:

Panel:

1. Permission manager (root, admin, user, seo): hiding logs and tabs for each user.
2. Creating a user with any duration (access to the panel).
3. Sorting bots by several types/searching for bots by ID, IP.
4. Moving bots to Favorites, blacklist, trashlist. Convenient when the panel has a lot of bots.
5. Viewing/searching for/editing injects. There are about 400 injects.
6. History for the last five commands.
7. Battery status / phone model / IP address / phone number / OS version.

Nice and convenient service.

Bot:

1. Send SMS messages
2. SMS spam
3. Get accounts
4. Send fake push notifications
5. Read push notifications
6. Read SMS messages
7. Stealthily intercept SMS messages
8. Turn off sound
9. Lock the screen
10. Get admin rights
11. View contacts
12. View a list of installed apps
13. Clear push notifications
14. Keylogger
15. Call forwarding
16. Launch an application
17. Open a link in the browser
18. Clear app data
19. Open an inject
20. Auto inject when opening an application
21. Delete an app
22. KillBot

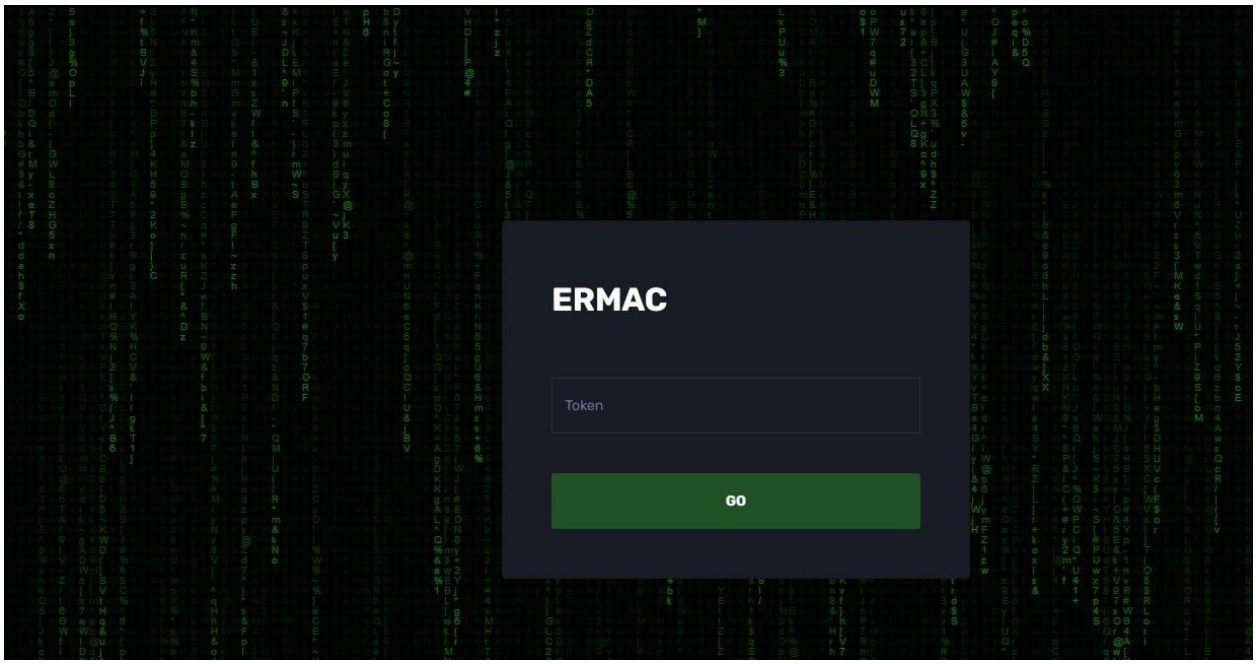
Additional functionality:

1. Block 130 antiviruses and battery optimizers
2. Multiple languages
3. Anti-deletion
4. Disable accessibility
5. Hide icon (not on all devices)
6. If the user does not give permission, a push notification teases them, asking them to enable rights.
7. Double SIM Card

8. Works on all devices and automatically gets rights, including on Honor and Xiaomi
9. Spare IP addresses for beaconing

The malware is rented out at $3,000 per month.

The admin panel:



Threat name	Detection	Regions attacked
Aberebot	July 2021	Global

July saw the discovery of a malware sample dubbed Aberebot. The malware is at its early testing stages and is actively being promoted on underground resources and in Telegram channels.

Functionality:

- Searching for and exfiltrating banking credentials
- Intercepting SMS messages to bypass 2FA
- Support for web fakes
- Exfiltrating contacts
- Exfiltrating the victim's Gmail accounts

According to the author, the bot has ready-made web fakes for banks from Australia, Austria, Canada, Czech Republic, Germany, Spain, France, Hong Kong, India, Italy, Japan, the Netherlands, New Zealand, Poland, Romania, Turkey, the UK, and the US.

The developer of the malware is believed to be a threat actor from Turkey.

Threat name	Detection	Regions attacked
Cerberus	April 2020	Turkey

The Android banking Trojan Cerberus v2 can send and intercept SMS messages, show web fakes to the user, record keystrokes (keylogger), launch applications installed on the device, bypass security restrictions and antiviruses, create fake PUSH notifications, and open URLs in the browser.

This malware is an updated version of the Cerberus Android bot created in June 2019. Later in 2019, the source code was published free of charge for premium users of one forum. Posts with the Trojan's source code continue to be occasionally published on underground forums, which means that many threat actors are using it.

In Q3, Cerberus was distributed in Turkey disguised as the Play Store app, it was observed.

Threat name	Detection	Regions attacked
FlexNet	2014	Russia

The Trojan requests device administrative privileges. The request text is masqueraded as a Google Play agreement, which distracts the user and helps access privileges.

On command from a C&C server, the application can:

- Change the C&C server address
- Send an SMS message to a specified number
- Send bulk SMS messages with a specified text
- Forward SMS messages to a remote server
- Reply to SMS messages and delete them to conceal the fact from the user
- Run USSD requests
- Schedule commands: configure a command template for new bots for a particular operator and country

In addition, FlexNet had phishing dialog boxes added to its functionality. They are disguised as popular applications and designed to obtain victims' bank card details. The following fake dialog boxes were detected:

AliExpress
Alpha
Avito
Google Play
MyNewAlpha
telecard
VTB24
Sberbank
Uber

Threats and malware for PC

Threat name	Detection	Regions attacked
Inter-Group-23 threat group	September 2021	Global

The threat group Inter-Group-23 started its activity in July 2020. The group uses a JS sniffer called Inter (which is sold by a threat actor with the username Sochi) for attacks against websites powered by CMS Magento. According to Group-IB specialists, throughout its activity the group infected at least 126 websites and in Q3 2021 stole 18,000 customer bank cards. The group uses obfuscated samples of the Inter sniffer with forged payment forms to collect payment information.

Threat name	Detection	Regions attacked
Improved-ImageId threat group	2019	Global

The threat group Improved-ImageId has been active since mid-2018. It uses a modified version of a sniffer developed by a threat actor with the username poter for attacks against e-commerce websites. Throughout its activity the group infected over 100 websites and stole more than 57,000 bank cards. In Q3 2021, however, the group's activity decreased for unknown reasons.

Threat name	Detection	Regions attacked
zLoader/Silent Night	November 2019	USA Japan Germany Australia Canada

This Trojan was put up for sale in late 2019. At the end of Q1 2020, it started being used in the wild. It is mostly distributed through mailouts with a macro-containing Excel file, which downloads zLoader.

Group-IB specialists discovered and analyzed the zLoader panel and established that users in the US (primarily), Japan, Germany, Australia, and Canada were the botnet's victims. The panel has a total of 58,000 bots; at the time of the analysis (September 2021), 1,130 of them were online.

It was established that the botnet operators' goal was to access their victims' bank accounts. In six months, the threat actors compromised over 200,000 accounts (in addition to bank accounts, however, these include other accounts victims enter in their browser). The accounts have been loaded directly in the Group-IB TI&A system.

The Admin panel:

Stats | Bots | Backconnect | Reports | Logout

Bots		Processes	
Botnets		Countries	
Markers		IP-addresses	
Comment		AV bots	☐
Online status	-	Domain bots	☐

Filter

Num of bots: 54904

Bot ID	Botnet	Marker	Version	IP	Install date	Comment	Online time	
DESKTOP-1I7SB88_4967307458331170	vasja	vasja	1.6.28	[redacted] | DE	26-07-21 09:21	-	00:00:54	☐
DESKTOP-5IR07O1_4967307462265 70D	vasja	vasja	1.6.28	[redacted] | US	26-07-21 09:14	-	00:08:04	☐
JESSE-HP_2EBFF1F48090C4F9	vasja	vasja	1.6.28	[redacted] | US	26-07-21 09:06	-	00:16:37	☐
DESKTOP-733NA0V_49673074B6FB051B	vasja	vasja	1.6.28	[redacted] | DE	26-07-21 08:49	-	00:33:27	☐
STEVE-PC_49673074A8DACSCA	vasja	vasja	1.6.28	[redacted] | US	26-07-21 08:47	-	00:35:35	☐
DESKTOP-TESVRKN_49673074EA9C7A3C	vasja	vasja	1.6.28	[redacted] | AU	26-07-21 07:52	-	01:06:20	☐
DESKTOP-4UH52PB_49673074D26948DB	vasja	vasja	1.6.28	[redacted] | MA	26-07-21 07:34	-	--:--:--	☐
DELL_496730747C59F195	vasja	vasja	1.6.28	[redacted] | IN	26-07-21 07:15	-	02:06:55	☐
DANNY-WAKU-PC_49673074AF30740B	vasja	vasja	1.6.28	[redacted] | DE	26-07-21 06:51	-	02:31:25	☐
DESKTOP-NJTENHQ_49673074EAD3E884	vasja	vasja	1.6.28	[redacted] | VE	26-07-21 06:09	-	--:--:--	☐
LAPTOP-2GPUPUKK_49673074FCB0B41F	vasja	vasja	1.6.28	[redacted] | DE	26-07-21 05:16	-	--:--:--	☐
DESKTOP-PMAMO5L_4967307490200DD0	vasja	vasja	1.6.28	[redacted] | TH	26-07-21 04:52	-	--:--:--	☐
LENOVO-H415_2EBFF1F475CF9AAE	vasja	vasja	1.6.28	[redacted] | US	26-07-21 04:10	-	04:23:14	☐
KATHY-PC_2EBFF1F44F83BBE5	vasja	vasja	1.6.28	[redacted] | US	26-07-21 04:00	-	--:--:--	☐

In late September, researchers at Microsoft reported that they had discovered a new zLoader distribution tactic. Threat actors started using online ad platforms. They used ads pointing to websites where malware disguised as legitimate installers was hosted.

Threat name	Detection	Regions attacked
Trickbot	2016	Global

Since 2020, in addition to being used as a banking Trojan, Trickbot has been used in ransomware attacks. In Q3, Trickbot was used in operations by the TA551 (Shathak) group together with the malware DarkVNC and CobaltStrike.

In 2020, Trickbot was fitted with new features:

- Bypassing UAC in Windows 10 (it was previously available only for Windows 7) to deliver malware to numerous machines in the target network.
- Use of Windows 10 ActiveX to execute malicious macros.
- Module for using hacked machines for RDP brute-force attacks.
- In May 2020, Palo Alto Networks discovered that Trickbot's propagation module called nworm had been updated. Infections caused through it leave no artifacts in the victim's domain controller, which disappear after a reboot or shutdown. It is run from RAM. In addition, unlike the previous module (mworm), the new module transfers Trickbot's executable file in encrypted form.

- In October, a new Trickbot feature was discovered, which enables threat actors to tamper with UEFI/BIOS. The new module checks the SPI controller to see if BIOS write protection is enabled. The module has not been witnessed modifying the firmware itself, though it already contains code to read, write, and erase firmware. The new module has not yet been detected in use in actual attacks.
- In February 2021, a new component was added. It performs local network reconnaissance. Named masrv, the component incorporates a copy of the Masscan open-source utility in order to scan local networks for other systems with open ports. The idea behind masrv is to drop the component on newly infected devices, send a series of Masscan commands, let the component scan the local network, and upload the scan results to a Trickbot C&C server.

Even though a Trickbot member (Latvian citizen Alla Witte) was arrested in June and another developer was arrested in September in South Korea, the malware is still active.

Threat name	Detection	Regions attacked
Gozi (ISFB, Ursnif, Dreambot)	2007	Italy

Gozi/ISFB is a banking Trojan that was created quite a long time ago. In 2020-2021, Group-IB specialists observed the use of Gozi 2.X and Gozi v3.
The malware's main features include:

- MITB (Man-In-The-Browser) attacks using web injects
- Theft of user accounts from infected devices
- Execution of CMD commands
- Download of files to an infected device and their execution
- Extension of functionality through the download of additional modules from the C&C server
- Video recording

Q3 2021 saw Gozi samples targeting Italy. The attacked banks include:
unicreditgroup.eu
unicreditcorporate.it
agenziabpb.it
ing.it
sella.it
chebanca.it
nexi.it
cariparma.it
carispezia.it
friuladria.it
banking4you.it
fideuramonline.it
seceti.it
bpergroup.net
popso.it
bancobpm.it
intesasanpaolo.com
gruppocarige.it
tecmarket.it
mps.it
cbibanking.it
bancagenerali.it

poste.it
ubibanca.com
finecobank.com
bnl.it
creval.it
csebo.it
inbank.it
cedacri.it
credem.it
relaxbanking.it
unipolbanca.it
chebanca.net
unicredit.it
credit-agricole.it

Threat name	Detection	Regions attacked
IcedID (aka Bokbot)	2017	Global

IcedID was first detected in late 2017. The malware can be used to steal financial information and launch targeted attacks. IcedID is mostly distributed using Emotet but also through phishing emails with a malicious macro that downloads and launches IcedID.

IcedID has a modular architecture and many features of Zeus, including web injects, data theft, and the ability to inject code into other processes. One of the bot's distinct characteristics is its ability to deploy a proxy server on an infected machine and redirect all Internet traffic using that server.

In addition to banks, IcedID currently attacks e-commerce businesses. In either case, threat actors' aim is to obtain bank card details: card number, CVV, expiration date, and the region where the victim is located.

In May 2020, Group-IB specialists analyzed a new version of IcedID (21st one), in which configuration files were hidden in PNG images. In earlier versions (e.g., 12), the PNG file only contained the main module.

In mid-2020, it was discovered that the Valak loader started to be used to distribute IcedID.

In 2021, IcedID was primarily used to distribute ransomware such as Revil, Conti, and RansomEXX. The distribution schemes were the following:

- Spearphishing Attachment (Possible SilentBuilder) -> GZIPLOADER -> IcedID -> Cobalt Strike-> BloodHound -> AdFind -> Rclone -> Revil
- Abusing Contact Forms Campaign-> Redirect to Google Sites -> ZIP archive with JS -> GZIPLOADER-> IcedID-> Cobalt Strike -> Conti

In Q3, security specialists discovered instances of IcedID being used to distribute Conti. The malicious emails were in English.

Threat name	Detection	Regions attacked
Qbot	2009	USA, Canada

Qbot (QakBot) emerged in 2009 and has since been regularly improved. Qbot is a modular multithread Trojan that can steal banking data, digital certificates, authentication tokens, and cookies as well as function as a keylogger, backdoor, and SOCKS proxy; it also has antivirus evasion features. Qbot is

designed to target businesses and steal money from their bank accounts. The Trojan is distributed as a worm by self-replicating through shared drives and removable media.

In 2020, the Qbot operators, as well as those of other banking Trojans, decided to shift their focus toward distributing ransomware. In particular, the Qbot operators worked with the Egregor ransomware. They later worked with the DoppelPaymer ransomware.

In the latest Qbot updates, the network protocol and security mechanisms (security checks on the server side) have been improved. A security check has been integrated to send data only one hour after a bot registers in the botnet.

The configuration file of active Qbot samples contains the following targets:
Chase
BB&T
Citizensbank
Capitalone
Firstcitizensonline
Suntrust
Wellsfargo
Frostbank
Scotiabank
Bank of America
Bank of Montreal
Royal Bank of Canada
Citibank
Bank of the West
EastWest Bank
Fifth Third Bank
HSBC
JP Morgan
Mandt Bank
The PNC Financial Services Group
TDBank
Usbank
Amegybank
National Bank of Arizona
Vectrabank
Zionsbank
Schwab
Desjardins
Scotiabank

Ransomware

Threat name	Detection	Regions attacked
AvosLocker	July 2021	Belgium Spain Saudi Arabia Turkey Lebanon Germany UK USA

In July–September, the following companies were attacked:

Artas Holding / Artas Insaat
Algeciras, S.L
Home in Brussels
Arabian Cargo Group
Heller Injury Lawyers
Breydons Solicitors
Geneva, Ohio
Coghlin Electrical Contractors
Mauck & Baker
Moorfields NHS UK & Dubai
Gimmler Gruppe
Master Chemical
Potter Concrete
Pacific City Bank

Threat name	Detection	Regions attacked
BlackMatter	July 2021	Global

Below is a list of companies attacked in Q3:

Helman Hurley Charvat Peacock / Architects, Inc.
Pine Labs Pvt
Huck Bouma PC
Solar Coca-Cola
Middleton Reutlinger
Academia de Idiomas y Estudios Profesionales
Kaydon Corporation
Marcus & Millichap - Real Estate Investment Services
G-ABLE Co., LTD.
Diamond Schmitt
Network Telecom / Enreach
Tasteful Selections & WFG
Trust Capital Funding
Eisvogel Hubert Bernegger GmbH

Ellerboeck
River City Construction
EQUITY TRANSPORTATION
Spectrum Industries Inc.
Modern Testing Services
Pulmuone Co., Ltd.
Citrocasa GmbH
Actief-Jobmade
Pramer Baustoffe GmbH
CasagrandeGroup
BCP Securities
JMclaughlin
LA-Martiniquaise
Bumper to Bumper Autoparts
Crystal Valley

Threat name	Detection	Regions attacked
Vice Society	May 2021	USA France Italy Netherlands Germany

In July–September, the following companies were attacked:

Walter's Mercedes-Benz of Riverside
Gateway College
Walter's Automotive Group
Centre Hospitalier D'Arles
3V Sigma
Eskenazi Health Foundation
Plastipak Holdings, Inc.
Butali
Barlow Respiratory Hospital
ROC Mondriaan
United Health Centers
KESSEL AG

Threat name	Detection	Regions attacked
Cl0p Ransomware	February 2019	USA India Canada

Below is a full list of companies attacked in April–June 2021:

FOODLAND
BOUTINEXPRESS
Resources for the Future
Aurobindo
Utilitytrailer
Kss architects llp
Sgs-law
Valley truck & tractor

Threat name	Detection	Regions attacked
Conti	February 2020	Colombia USA France Canada Austria UK Italy India Germany South Korea Bangladesh Ireland Australia Indonesia Dominican Republic

Below is a full list of companies attacked in April–June 2021:

CODIFER S.A.S
D.A. Blodgett St. John's
FE Moran Security Solutions
Klenda Austerman LLC
cross city church
groupe-upperside
Titanium Industries Inc
Comfort Keepers
CAVENDERS
Hensley Beverage Company
Broward County Public Schools
IPSEN
The Village Vets
Capmatic
OpTech Staffing Solutions
Matco-Norca
Edifice General Contractors

Citizens Of Humanity
Kaleidoscope Charter School
DirickX
Complete Automation
DDSG Logistics
Bauder Roofing Solutions
Flaghouse
Bertucci
Filtertek
Precision Terminal Logistics
C.E.E. Schisler Packaging Solutions
Brown Strauss Steel
Options Greathire Ltd
Readie Construction Ltd
PNGC Power
Interfel Corp
Plimpton and Hills Corp
Ford Meter Box
Cairn Capital
HumanWare
Apperton
HW Fisher
aspire inc
SpecPage
TRACTOR CENTRAL
Jacquet Metals Group
Execu Search Group
Travers Tool Co Inc
MISSION IMPRINTABLES
Wizie
PCH International
Bee County Texas
Tasman Butchers
Intermountain Farmers Association
Waikato District Health Board
Riwega S.R.L.
AZ INVESTIGATION
ARWORLD
Mauffrey Group
Transports P. Fatton Inc.
Seifert Logistics Group
MOSS BROS GROUP
Loudoun Mutual Insurance Company
LG CNS
RIB GROUP
DigiCon Technologies Limited
Hentzen Coatings, Inc.
HBD Industries, Inc.
Finolex Cables Ltd.
empire physicians Medical Group
B.P. MITCHELL HAULAGE CONTRACTORS LIMITED
Michael Stevens Interests, Inc.

Vendrig Holding B.V.
Cairns Marine
TURLA SRL
Birtcher Anderson & Davis Associates, Inc.
Cable Color S.A. de C.V.
PT. Realta Chakradarma
TELCAL srl
Sanger & Altgelt Insurance Agents
RPE CONTRACTING
Ireland's Health Service Executive
Electronic Environments Co. LLC
MHA MacIntyre Hudson
ResCon Group
Frank G. Love Envelopes, Inc.
PT. Realta Chakradarma
Bartec Gmbh
Ash Industries, Inc.
Creative Liquid Coatings, Inc
STAM
Moor Park High School
Technical University of Berlin
Funbreak
SEVES Group SpA
BVA Group
Pure Power Technologies
DSD PARTNERS
Antwerp Local Schools
East Texas Alarm
Pure Power Technologies
Temmel Logistik Center
National Louis University
Southwest Recovery Services, LLC
Xpressdocs
La Innovacion
Birmingham Barons
King's Seafood Company
University of Corboda
Nissin International Transport U.S.A., Inc.
Strongco
Thomas Westcott
A&A MECHANICAL
PLURIPHARMA SRL
TPI Corporation
Stride Tool
DSD PARTNERS
eCapital
The Brock Group
Cerfrance Côtes d'Armor
Groupe ISERBA
Sunsations Inc.
BRANGEON Groupe
Vogel Heating & Cooling

Contrast Lighting
Au Forum Du Batiment SAS
Ascenz
Sunsations Inc.
Maître Prunille
Groupe Traon Industrie Development
Windmill Health Products
Voltalia
Uniware Systems
City of Tulsa
Goetze Dental
USI
Cerfrance Côtes d
Proponent
The Waterloo Networking Company
Southern Eagle Distributing
Cambium Inc
Scott Felder Homes
Lareau Courtiers d'assurances
FNA GROUP
KOMPAN A/S
Grupo Herdez, S.A.B. de C.V. Holding Companies
Sleep Outfitters
Engineered Specialty Products, Inc
Nickerson Insurance Services, Inc
Perfume Worldwide Inc.
JAMAC FROZEN FOODS
Concept Building Services
Fischer Homes
DAVACO Inc
Dynamic NC

Threat name	Detection	Regions attacked
LockBit	December 2019	Global

Below is a list of companies attacked in July–September:

Grupo DINA S.A.
Alcedo
Aquazzura Firenze
Dragon Capital Group
Salzburger EisenbahnTransportLogistik GmbH
Colligan Law LLP
Swift Group functions
Kennen SRL
Comet Group

Rio Star Foods INC
CEC Engenharia
SAHİN TOPTAN GIDA
Beton Lucko
Siro Group
CCZ Statton
Anders CPA
SERVER-FLAMINIO
CSP Mould
Vincents Accountants
Dial Alimentos
Goncay Plastik
Lone Wolf Technologies
Southern Steel Group
Moris Adjmi Architects
First Financial Mortgage
United Mortgage
Lanex
OTC Qatar
KMA Zuckert
Hotel Luzeiros Fortaleza
Grupo Protege
YMCA DC
ERG S.p.A
Julian&Grube
Bennetts
Nutrifood
FUWL
Hoi Meng Trading
EDYCE Corp
MASCHERPA TECNOLOGIE GESTIONALI srl.
Yazaki Corporation
HITECH PIPING Ltd
Gicinque S.p.A. Cucine
Verisilicon
Teyliom
Sabre Corporation
YAMATO-ESULON Co., Ltd.
Inline Plumbing
GD Express Sdn Bhd
JACCS CO., LTD.
Smith, Gambrell & Russell Law
MEGAWATTS
ESR Motor Systems
Petrologis Canarias
The National Wild Turkey Federation
Sabre Instrument Services Ltd.
Accenture
NusantaraRegas
JINYANG OILSEAL
Melpaper SA
MK Brokers AD

Audit Treuhand AG
Mecc Alte
Banco Comercial de Angola
Marlabs
Salee Printing PCL
Seliner Schreinerei AG
Pulmuone Foods USA, Inc.
Pike County Sheriff's Office
J. Jaramillo Insurance
Beardow Adams
Ceratube
Living Flame
Le Monastere
iSoftStone
Ford Deckx
Vincents Accountants
Ethiopian Airlines
Nexans autoelectric
Saltos del Francoli S.A.
Delran Township
ABECHO
Envision Credit Union's
Faber Industrial Technologies
Alta Electronics Inc.
Service Istanbul
The Zambian Border Crossing Company
The Frager law firm
Paladin Advisors
Bangkok Airways
NEP Group
ConMoto
Stetson Convention Services
Bruns Realty
Softvision
Nutrix Public Company
Yakima Co-op
Jogn Bead
Hellmich + Partner
Overseas AST
Pride Pak
Pike County Sheriff's Dept
MAXIMUS
ADVINT
D. Sims Crawford Chapter 13 Standing Trustee Law Firm
Autohaus Daehn GmbH & Co KG
Prototal Industries
Baroli Technologies
Denver Housing Authority Company
ODEF Financiera Company
Soenen Golfkarton NV
Remedios
HPE-Konstanz

Cheadle law
Benner Sistemas SA
Absolute Communications and Network Solutions Inc.
AEROGRAFICOS GAHE SA
Comebi
HB Finanse
CanSmart
ERG
PI Financial Corp.
Suenco
Tesa 46
Tovo Gomma
Odin Feldman Pittleman
Russell WBHO
Maser
Royal Porcelain Public Company Ltd.
ATS Track
RMS Law
Miller & Rose
Riscossa
Northstarak, LLC
AGM Financial Services
Novotech
NRPA
Associação Brasileira de Cimento Portland
Denark Construction
DRS Doors
Wester Spirits
Noone Imagewear
China Online Education Group
IBES Baugrundinstitut GmbH
Grupo Wec
John Cockerill
Sheraton
DYNAMIC SUPPLIES PTY. LTD.
Integrated Information Services
Glenroy
Dykman
Hotel ServicePro
Doyle Restrepo Harvin & Robbins LLP
eSoftware Professionals
Hoffsümmer
Wijnen De Clerck
Ebarc Advogados Associados
J. Addington General Contractors, INC.
Jerry Leigh
J&P Legal
Day Lewis
Buffington Law Firm PC
TES
Robson Street
SETE

AGM Financial Services, INC.
Jaylon
Franklin Empire
Compagnie de Papiers White Birch Canada
Advantec MFS, Inc.
Peabody Properties
Data Speed
SCIS Air Security
Country Grocer
Anasia
Vlastuin Group
Alder King
Hoist & Crane Service Group
Amista
Rabbalshede Kraft
Geda
Newhotel Software
Fugybat
Texas Ace Heating & Air
Tecnopiso
Transportes De Mercadorias Rendufenses

Threat name	Detection	Regions attacked
Ragnarok	January 2020	Romania Italy Canada Bolivia USA

Below is a full list of companies attacked in July–September 2021:

WONG & TANG SOLICITORS
Bangkok
Lemeks
Emmegi
MANIPULADORA DE MERCANCIAS SL
Group Profil France
Pachmayr
Quality Reputation Sdn Bhd
Thiensurat Public Company Ltd.
Hitit Gümrük
DAE MYUNG RAINWEAR LANKA (PVT) Ltd.
Lemeks Sadamad AS

Threat name	Detection	Regions attacked
Grief	May 2021	Global

Below is a full list of companies attacked in July–September 2021:

Evron Foods Limited
Booneville School District
Salzburg Milch
Commune De Villepinte
Naz Financial Services Inc
HDHC Home Decor
Puntacana Group
INDUSTRIAS VIDECA SA
County of St Clair
Rehabilitation Support Services, Inc.
Clover Park School District
Mobile County, Alabama
Woodruff Institute
Comparis AG
Evron Foods Limited
Sierra Air Conditioning
Landkreis Anhalt-Bitterfeld
PCM Group
Lancaster Independent School District
Oz Architecture, Inc.
Orange County Chrysler Jeep Dodge Ram Dealership
LENAJA DISTRIBUTION
American Cotton Coop Association
Booneville School District
Salzburg Milch
Commune De Villepinte
Evron Foods Limited
Matisa MatÃ©riel Industriel S.A.
LENSBURY LIMITED
City of the Saloniki
Socfinaf
Kocks Ardelt Kranbau GmbH
UNISELF - SOCIEDADE DE RESTAURANTES PÃšBLICOS E PRIVADOS, S.A.
Chamco Industries Ltd
ATIVY CYBER SECURITY
OAKES MILLERS LIMITED
CROMOLOGY SERVICES
BONTEMPI VIBO SPA
C & C FRANCE
Greensville County Public Schools
Gaulhofer Industrie-Holding GmbH
Roosevelt School District No 66

FEDERFARMA.CO DISTRIBUZIONE E SERVIZI IN FARMACIA SPA
2CRSI
TK Elevator Innovation and Operations GmbH

Threat name	Detection	Regions attacked
RansomExx	March 2020	Global

Below is a full list of companies attacked in July–September 2021:

WT Microelectronics
Walsin
Corporación Nacional de Telecomunicación
Liberty Group & ForHousing
Ermenegildo Zegna Holding
GIGA-BYTE Technology Co., Ltd
American Megatrends International
United Carton Industries Company Ltd

Threat name	Detection	Regions attacked
Ragnar Locker	December 2019	USA Canada

Below is a full list of companies attacked in July–September 2021:

GatewayPM
Primary Residential Mortgage inc.

Threat name	Detection	Regions attacked
XingTeam	May 2021	Italy UK USA

Below is a full list of companies attacked in July–September 2021:

DiaSorin
Paxton
J.Irwin
Access
Compan

Threat name	Detection	Regions attacked
REvil	April 2019	USA Germany Brazil Jamaica Spain UK Turkey Netherlands Norway

Below is a full list of companies attacked in July–September 2021:

CABLEX Group
CYMZ
JN Bank Limited
Masmovil ibercom SA
Trevor Sorbie
KREBS + KIEFER
Vic Pharma Industry and Trade Ltd.
NERO Industries
Asfalt Productie Nijmegen
Ghilotti Bros. Inc
Law Offices of Michael B.
Daylesford
Inocean
Hx5, LLC
South Carolina Legal Services
Ensinger
Kaseya
Ohio Grating Inc.
Spiezle Architectural Group Inc.

Threat name	Detection	Regions attacked
Cuba	November 2019	Global

Below is a full list of companies attacked in July–September 2021:

Forefront Dermatology
GasCaribe
Quercus
BlackHawk

Lycra
Technicote
Berding-weil
Nwdusa
Creditriskmonitor
Linkmfg
Phminc
Axley
Schultheis-ins
Ohagin
Meriple

State-sponsored APTs

APT name	Regions attacked	Operation start
GhostEmperor	Malaysia, Thailand, Vietnam, Indonesia, Egypt, Ethiopia, Afghanistan	July 2020

Security specialists discovered a new Chinese cyber espionage group called GhostEmperor, which had attacked major organizations since at least July 2020. GhostEmperor has attacked government entities and telecommunications companies in South-East Asia (Malaysia, Thailand, Vietnam, and Indonesia), Egypt, Afghanistan, and Ethiopia.

The entry point for GhostEmperor's hacks were public-facing servers. The analysts believe the group used exploits for Apache, Oracle, and Microsoft Exchange servers to breach a target's perimeter network and then pivoted to more sensitive systems inside the victim's network.

The hackers used an assortment of different scripts and tools to deploy backdoors inside a victim's network. This backdoor was then used to download and run Cheat Engine to bypass the Windows PatchGuard security feature and install a rootkit called Demodex inside the victim's Windows OS. The researchers said the rootkit was extremely advanced and allowed the group to maintain access to the victim's device even after OS reinstalls and even on systems running recent versions of the Windows 10 OS.

GhostEmperor traffic is usually disguised as RIFF, JPEG, or PNG files. The group uses highly sophisticated tools and is often focused on gaining and keeping long-term access to its victims' networks.

APT name	Regions attacked	Operation start
CNC (aka APT-C-48)	China, South Asia	2019

CNC (APT-C-48) is a new group that emerged in 2019. It was called so based on the PDB of a remote access Trojan used by it, which contains the phrase "cnc_client." The hackers' main target is the Chinese military and education sector. At the beginning of the epidemic early last year, CNC carried out an attack on the medical industry by forging documents related to the epidemic and using phishing websites.

360 Advanced Threat Research Institute has recently observed that CNC organized multiple targeted attacks on China's scientific research institutions, universities and aerospace-related fields. The researchers named this attack Operation Sky Hunting.

In this attack, CNC used two attack methods. The first method relied on multiple GitHub accounts to transfer and distribute data at each stage. The threat actors created phishing pages showing a fake Flash Player update. It was found that a modified version of GRAT2 was dropped to the victim's system.

The second method is different in that after the sample runs, different operating strategies will be adopted according to the presence or absence of a network environment in an attempt to steal document data from a partially isolated network environment.

Experts found overlaps with other cyber espionage groups such as Baby Elephant and Sidewinder.

APT name	Regions attacked	Operation start
TaskMasters and TA428	Russia	2020

In mid-May 2021, SOLAR JSOC experts together with the Russian National Computer Incident Response & Coordination Center (NCIRCC) released a report about a series of targeted attacks detected in 2020. According to the report, the attackers targeted Russian federal executive authorities.

Group-IB analyzed malware used in the attacks, Webdav-O. The malware has a lot in common with the popular Trojan BlueTraveller, which is linked to the Chinese threat group TaskMasters and used in cyber espionage operations whose goal is to steal confidential documents.

In-depth analysis of TA428's tools showed that BlueTraveller had a lot in common with the Albaniiutas malware, which has been attributed to the group in December 2020. In other words, Albaniiutas and Webdav-O are updated versions of BlueTraveller.

Interestingly, Chinese hacker groups actively engage in exchanging tools and infrastructures and this is exactly what may have happened in this case. This means that one Trojan can be configured and modified by hackers from different groups with different levels of training and various objectives.

You can find more information in our blog post https://blog.group-ib.com/task.

APT name	Regions attacked	Operation start
DeadRinger attack	South-East Asia	2017

Security experts found that at least five major telecommunications providers in South-East Asia that serviced tens of millions of customers had been hacked by at least three different Chinese hacker groups.

The discovered attacks have been linked to three groups:

- APT10 (Gallium, Soft Cell)
- Naikon APT
- TG-3390 (also known as APT27 and Emissary Panda)

Some of them were active in their victims' networks for many years, with some hacks taking place as early as 2017.

All the groups have been linked to the Chinese government. In addition to often using similar tools and tactics, the groups attacked the same targets simultaneously.

The hackers' methods included using Microsoft Exchange Server vulnerabilities, installing the China Chopper WebShell, using Mimikatz to steal credentials, and creating Cobalt Strike beacons and backdoors to connect to a C&C server.

In each wave of attacks, the threat actors' aim was to facilitate cyber espionage by collecting sensitive information, compromising high-profile business assets such as billing servers that contain Call Detail Record (CDR) data, as well as key network components such as domain controllers, web servers and Microsoft Exchange servers.

APT name	Regions attacked	Operation start
ITG18	Iran	August 2020

IBM Security X-Force threat intelligence researchers continue to track the infrastructure and activity of a suspected Iranian threat group ITG18. This group's tactics, techniques, and procedures (TTPs) overlap with those of groups known as Charming Kitten, Phosphorus, and TA453.

Analysis led to the discovery of a malicious tool that had not been previously linked to this threat actor, a custom Android backdoor dubbed LittleLooter. LittleLooter is functionally rich and includes capabilities to record video, make calls, record sound, and gather location information.

Despite public reporting of their OPSEC mistakes, ITG18 continues to leave archive files containing exfiltrated victim information on open servers and in open directories. The new analysis revealed that ITG18 had exfiltrated roughly 120 gigabytes of information from approximately 20 individuals aligned with the Reformist movement in Iran.

APT name	Regions attacked	Operation start
Lorec53	Georgia, Ukraine, other countries in Eastern Europe	March 2021

Another threat group was active during the period in question. The hackers were dubbed Lorec53 and are reported to have been active in early 2021. The group conducted a number of attacks against Georgia, Ukraine, and other countries in Eastern Europe. Information on the behavior trajectory indicates that the hackers may currently be employed by a higher-level spy organization to help them gather information.

In its cyber espionage activities, Lorec53 produced and deployed various Trojans such as LorecCPL and LorecDocStealer. Such programs have not yet appeared in other espionage activities.

Some network facilities controlled by Lorec53 were found to be used to operate other botnets including Predator and Formbook. Presently, these botnet operations do not have much overlap with the attack intentions and common methods of Lorec53, and it is impossible to find a direct connection between the attackers. Security specialists believe that Lorec53 may have borrowed the servers of other hacker organizations to transfer or distribute its Trojans.

At the moment, no key evidence that would help clearly identify the geographic location of Lorec53 has been found. However, related attacks indicate that Lorec53 prefers to use attack resources from Russia, including servers belonging to Russian service providers and registrants, and Trojans from Russian hacker forums.

APT name	Regions attacked	Operation start
Tortoiseshell	USA	2019

The Iranian hacker group Tortoiseshell spent 18 months masquerading as an aerobics instructor in a cyber-espionage campaign designed to infect employees and contractors working in defense and aerospace with malware in order to steal credentials and other confidential information.

Active since at least 2019, the campaign used Facebook, Instagram and emails to pose as the fake persona Marcella Flores. The attackers could spend months building up a rapport with targets via messages and emails before distributing malware.

It was not until early 2021 that the threat actors used a Gmail account owned by the defunct Flores to attack. From this mailbox, as part of long-standing correspondence, the hackers sent their victims links to OneDrive, which led to a document with a diet survey or video file. The decoy was used to distribute an updated version of the Lideric malware, which the researchers call Lempo.

Lempo secretly locks onto the victim's system, allowing attackers to search and steal sensitive information, including usernames and passwords.

Tortoiseshell (aka TA456 and Imperial Kitten) has been active since July 2018. The group is responsible for attacking 11 IT companies, most of which are based in Saudi Arabia. The group is believed to be supported by the Iranian government and linked to the Islamic Revolutionary Guard Corps (IRGC).

APT name	Regions attacked	Operation start
Bahamut	Middle East	2021

Security researchers came across a phishing campaign involving a hacker hosting malicious Android APK files on a counterfeit version of Jamaat websites.

This campaign is identical to earlier campaigns by the Bahamut group. The malicious app disguises itself as the Jamaat chat app and the Muslim Youth app.

The Bahamut malware requests the user for 21 different permissions, of which 14 are dangerous. When the user enables these permissions, the malicious app will collect information such as contacts, SMSs, call logs, and audio.

For all communication with the C&C server, the fake app uses a framework called Socket.IO, a real-time, bidirectional communication library. In addition, the Bahamut malware uses the HTTPS protocol to communicate with the C&C server.

The BAHAMUT APT group has been linked to a “staggering” number of ongoing attacks against government officials and private-sector VIPs in the Middle East and South Asia. The group is probably operating on a mercenary basis, offering their services to the highest bidder.

APT name	Regions attacked	Operation start
HEXANE	Israel	May 2021

HEXANE hackers associated with the Iranian government have focused attack efforts on IT and communication companies in Israel, likely in an attempt to pivot to their real targets. Security specialists reported that the threat actors used fake profiles to deliver malware to potential victims under the pretext of a job offer. They first identified the potential victim (employee), then identified a human resources department employee to impersonate. Following that, the threat actors created a phishing website that impersonated the target organization and set up a fake profile in the name of the HR employee.

The hackers then sent the victim to a phishing website with a lure file; a backdoor infected the victim system and connected to the C&C server over DNS and HTTPS, which was followed by a remote access Trojan (RAT) called DanBot being downloaded to the infected system. The hackers collected data for espionage purposes and tried to spread on the network.

Specialists at ClearSky say that the group spent months trying to breach a large number of organizations in Israel using supply chain tools.

HEXANE has attacked industrial enterprises since at least the middle of 2018. The group uses malicious documents to penetrate targeted networks. HEXANE focuses on the Middle East, Central Asia, and Africa. The threat actors direct their efforts against telecommunications companies, but these targets are used as a stepping stone in supply chain attacks. This way the group tries to get to ICS organizations that use the services of the telecom companies.

APT name	Regions attacked	Operation start

Confucius	Pakistan	2021

The theme of commercial spyware Pegasus by the Israeli firm NSO Group is used by cybercriminals in phishing campaigns. According to experts, the Confucius threat group has recently conducted a phishing campaign aimed at the Pakistani military.

The campaign involves a two-step attack. During the first phase, an email without a malicious payload containing content copied from a legitimate Pakistani newspaper's article is sent to the target. The sender address, which is spoofed, impersonates the PR wing of the Pakistani Armed Forces.

Two days later, a second email — purportedly a warning from the Pakistani military about the Pegasus spyware — containing a link to a malicious encrypted Word document and the password for decryption will be sent to the target. The sender address impersonates a service similar to that on the first email.

Clicking on either the link or the "unsubscribe" link will download a Word document. After entering the password mentioned in the message, a document containing macros is displayed on the screen. If the victim enables macros, malicious code will be loaded. The final payload is a .NET DLL file designed to steal documents and images.

Confucius is a pro-India APT group active since 2013. It has been mainly focused on Pakistani and other South Asian targets. For the past several years, however, it also switched to mobile malware, with the first Android surveillanceware ChatSpy being observed in 2018. The group may be linked to another Indian group, Patchwork.

APT name	Regions attacked	Operation start
SparklingGoblin	East Asia, South-East Asia, Canada, USA	2021

Security specialists discovered a modular backdoor, SideWalk, being used by an APT group dubbed SparklingGoblin. The backdoor shares multiple similarities with the CROSSWALK backdoor.

SideWalk is a modular backdoor that can dynamically load additional modules sent from its C&C server, make use of Google Docs as a dead drop resolver, and use Cloudflare workers as a C&C server. It can also properly handle communication behind a proxy.

The hacker group particularly focuses on the academic sector in East and South-East Asia, but it is also interested in the education sector in Canada, media companies in the US, and at least one unnamed computer retail company based in the US.

Symantec attributed the recently discovered Sidewalk backdoor to the China-linked espionage group Grayfly. Grayfly (aka GREF and Wicked Panda) is an APT that has been active since at least March 2017, using a custom backdoor known as CROSSWALK, a custom loader called Trojan.Chattak, Cobalt Strike, and ancillary tools in its attacks.

APT name	Regions attacked	Operation start
Tetris, web tool for espionage	China, Taiwan, Hong Kong	2021

Security researcher Imp0rtp3 discovered a web attack framework developed by a suspected Chinese government hacking group and used to exploit vulnerabilities in 58 popular websites to collect data on possible political dissidents: 57 of those sites are very popular Chinese sites, the other one is the site of the US newspaper the New York Times.

In addition, Tetris also abused legitimate browser features in attempts to collect user keystrokes, a large swath of operating system details, geolocation data, and even webcam snapshots of a target's face.

It was found that Tetris had been secretly uploaded on two websites with a Chinese readership. Users who landed on these two websites were first greeted by Jetriz, the first of Tetris' two components, which would gather and read basic information about a visitor's browser. If the user had the browser set to use the Chinese language, the would-be victim would be redirected to the second Tetris component named Swid, which would load 15 different plugins (JavaScript files) inside the victim's browser. Eight of the plugins would abuse a technique called JSON hijacking to open connections to popular websites and retrieve public data about the user on those sites.

APT name	Regions attacked	Operation start
Operation Secondary Infektion	Global	December 2020

Operation Secondary Infektion remains an ongoing information operation in present-day 2021, though the intensity of forgeries and articles has declined from its peak of activity between 2014 and 2020.

Security experts say that the Secondary Infektion operators attempted to infiltrate and influence individuals associated with or ideologically aligned to the far right in the US through attempting to fuel anti-Muslim sentiments and exacerbate COVID-19 disinformation.

Secondary Infektion relies on forgeries and fake media that attempt to enter local sources and penetrate mainstream news, typically targeting democratic governments and institutions abroad with stories intended to generate rage, confusion, and doubt in regional geopolitics. The operators behind Secondary Infektion take a keen interest in the affairs of governments operating in the former Soviet Bloc as well as those governments' domestic challenges.

APT name	Regions attacked	Operation start
Operation Armor Piercer	India	2021

Security experts recently discovered a malicious campaign targeting government employees and military personnel in the Indian sub-continent with two commercial and commodity RAT families known as NetwireRAT (aka NetwireRC) and WarzoneRAT (aka Ave Maria). The attackers delivered a variety of lures to their targets, predominantly posing as guides related to Indian governmental infrastructure and operations such as Kavach and IT-related guides in the form of malicious Microsoft Office documents (maldocs) and archives (RARs, ZIPs) containing loaders for the RATs.

Some of these lures and tactics utilized by the attackers bear a strong resemblance to the Transparent Tribe and SideCopy APT groups, including the use of compromised websites and fake domains.

Apart from the two RATs, the experts also observed specialized reconnaissance malware being deployed on the victim's endpoints. The attackers deployed a preliminary recon tool to enumerate specific folders looking for certain file extensions. The file listings/paths found are uploaded to an attacker-controlled C&C server.

A variety of mailers were used by the attackers to proliferate the maldocs, archives and download links:

- TeamCC ninjaMailer v1.3.3.7
- Leaf PHPMailer 2.7
- Leaf PHPMailer 2.8

APT name	Regions attacked	Operation start
FamousSparrow	France, Israel, Lithuania, UK, Saudi Arabia, Brazil, Canada, Guatemala, Taiwan, Burkina Faso	2019

A new APT group called FamousSparrow was discovered. The group has been active since at least 2019 and targets hotels, international organizations, engineering companies, and law firms worldwide. FamousSparrow's goal is believed to be cyber espionage.

Most of the attacks followed the same pattern, with the group using vulnerabilities in web applications as entry points into its victims' networks. The threat actors exploited vulnerabilities in Microsoft Exchange, SharePoint, and Oracle Opera (business software for hotel management).

Once FamousSparrow had a foothold inside a target network, the attackers deployed a custom backdoor named SparrowDoor, which they used as a pivot point to orchestrate ways to move laterally inside a hacked organization using public tools like Mimikatz and Metasploit.

APT name	Regions attacked	Operation start
New version of FinSpy spyware	-	2019

Security researchers spotted a new version of the FinSpy spyware, which can hijack and replace the Windows UEFI (Unified Extensible Firmware Interface) bootloader to infect the target machines. This way of infection allowed the attackers to install a bootkit without the need to bypass firmware security checks.

While in this case the attackers did not infect the UEFI firmware itself, but its next boot stage, the attack was particularly stealthy as the malicious module was installed on a separate partition and could control the boot process of the infected machine.

The new samples were protected by two components. The first component runs multiple security checks to ensure that the device it is infecting does not belong to a security researcher. Only when the checks pass, is the post-validator component provided by the server — this component ensures that the infected victim is the intended one. Only then would the server command deployment of the full-fledged Trojan platform.

All machines infected with the UEFI bootkit had the Windows Boot Manager (bootmgfw.efi) replaced with a malicious one. When the UEFI transfers execution to the malicious loader, it first locates and replaces the original Windows Boot Manager with a patched version capable of bypassing all security checks. On older machines that do not support UEFI, the security researchers observed infections through the MBR (Master Boot Record).

APT name	Regions attacked	Operation start
Attack involving NetwiredRC	Pakistan	June 2021

A phishing attack was conducted since late June; it mostly targeted Pakistani government organizations. By looking at the Email ID of multiple users, security specialists concluded that multiple sectors were targeted by the threat actor, including the energy, agricultural, chemical, educational, telecommunication and financial sectors. The attack has not been attributed to any group.

The email contained a malicious .docm attachment. The specialists observed multiple documents being delivered and all the documents had exactly the same macro content with the same URL to download the final payload. Once the document is opened, attackers try to trick the user by prompting them to enable macros to read the complete document. Once enabled, the macro downloads and executes the final NetwiredRC payload with the help of PowerShell. The payload is downloaded from the compromised website of the National College of Nepal located in Kathmandu.

NetwiredRC is a RAT for stealing sensitive information; it works on all operating systems. The Trojan's version in question involves sending collected information using a proxy server in an obfuscated form.

An earlier version of NetwiredRC was used by the APT33 group in 2016. At the moment, the available data is insufficient to attribute the discovered campaign to that group.

APT name	Regions attacked	Operation start
Aggah	Taiwan, South Korea	July 2021

In early July, spear-phishing emails targeted the manufacturing industry in Taiwan and South Korea. The Aggah group is believed to be behind them. One of the mailouts purported to be by FoodHub, a food delivery service. The body of the email contained order and shipping information along with an attached PowerPoint file named "Purchase order 4500061977,pdf.ppam." The email was sent to Fon-star International Technology, a Taiwan-based manufacturing company. Other spear-phishing emails were sent to:

- CSE group, a Taiwanese manufacturing company
- FomoTech, a Taiwanese engineering company
- Hyundai Electric, a Korean power company

Security specialists found obfuscated macros contained in the attached document that used MSHTA to execute JavaScript hosted on the compromised legitimate website of a hotel in India. Most of the compromised legitimate websites being used to host malicious scripts appeared to be WordPress sites. The JavaScript utilized anti-debugging techniques. After the debugging checks, the script returned another compromised website for an Afghan food distributor. Then a PowerShell process is created to execute a PowerShell file hosted on the compromised website. The PowerShell file checked for the antivirus status. Four conditions were checked: Windows Defender status, ESET status, whether Windows Defender is stopped, and whether neither are running. Based on these checks, a different loader was used to inject the Warzone payload into various legitimate processes. Warzone RAT is a commodity info stealer written in C++ that supports privilege escalation, keylogging, remote shell, downloading and executing files, file manager, persistence, and stealing credentials.

In September, a new way of hosting malware, using Zendesk and GitHub, was detected. Security researchers discovered an attack chain similar to one in the July attack, but the final payload was the Oski malware, which is sold on underground resources and includes capabilities such as stealing cryptocurrency wallets, stealing sensitive information stored in browsers (credit card data, autofill data and cookies), stealing credentials from various applications (FTP, VPN and web browsers), capturing screenshots, collecting system information, and downloading and installing additional malware. After it collects and exfiltrates the data, it will delete traces of itself in the system. In another case, Agent Tesla (a RAT that logs keystrokes and clipboard content) was detected among the final payloads.

Aggah is a cyber espionage group discovered in 2019; it is believed be based in Pakistan. Based on a number of similarities, it is thought to be associated with Gorgon Group.

APT name	Regions attacked	Operation start
APT-C-23	Middle East	September 2021

In September 2021, a new variant of Android malware targeting the Middle East and used by the APT-C-23 group was discovered. The malware masquerades as Google Play Installer, which, once opened, requests certain permissions and eventually shows the victim the Telegram messenger interface.

Once the malware is successfully executed on the affected Android device, it can perform several malicious activities without the user's knowledge. These activities include taking pictures, recording audio/screen, disabling WiFi, stealing call logs, stealing contact data, stealing files with certain extensions, making calls, deleting files from the device, taking screenshots, and recording calls on WhatsApp.

APT-C-23 (also known as AridViper, Desert Falcon, Desert Scorpion, DHS, Two-tailed Scorpion, and The Big Bang APT) is a politically motivated threat group that mainly targets Palestine government officials, diplomats, and other officials with the aim of obtaining information (espionage).

APT name	Regions attacked	Operation start
Attack against Alaska Department of Health and Social Services	USA	May 2021

In September 2021, unnamed threat actors gained access to the infrastructure of the Alaska Department of Health and Social Services (DHSS).

This activity was first detected on May 2. Initial access was gained by exploiting a vulnerability on a website. As a result of the attack, the threat actors potentially had access to the following user information: full names, dates of birth, Social Security numbers, addresses, telephone numbers, driver's license numbers, internal identifying numbers, health information, financial information, and historical information concerning a person's interaction with the DHSS.

The attack was stopped, but the investigation is ongoing, which is why no details have been disclosed.

APT name	Regions attacked	Operation start
DarkOxide	South Asia	2019

In September, security researchers discovered information about a previously unknown group called DarkOxide, which had been tracked since September 2019. The group targets organizations within the Asia Pacific (APAC) semiconductor industry. There was also a victim in the telecommunications sector. The targets of the attacks have included engineering staff with access to sensitive documents and source code.

Initially, the threat actors engage a target via a social media platform under the guise of carrying out a recruitment drive. The target is then encouraged to download a lure document purportedly relating to a job opening. In reality, this file is a malicious executable with a double file extension. When the payload is executed, it utilizes a number of scripting interfaces, including PowerShell and Visual Basic Script, to download a further malicious binary executable. This second executable in turn installs a copy of a legitimate remote access tool with a preconfigured C&C address. In a small number of cases the threat

actors also installed the Total Manager Pro file manager. It is likely that this was in order to conduct file system searches, or to package files for exfiltration.

As of at least March 2020, the group removed the first stage downloader and moved directly from the initial phishing attack to the installation of the legitimate remote access tool.

In June 2021, the attackers deployed additional tools, including Total Spy, RDP Wrapper, and DWServe, which are ready-made commercial products.

DarkOxide has been active since 2019. The group mainly targets the semiconductor industry in South Asia and aims to steal information. For their attacks, the group uses social media to distribute malware and legitimate tools to gain hidden access and work with files.

APT name	Regions attacked	Operation start
APT10	South-East Asia	2018

After discovering the Soft Cell campaign, security researchers continue tracking the threat group and discovered new activity targeting the telecommunications industry in various regions, primarily in South-East Asia. The first intrusions date back to 2018; the attacks continued until at least mid-2021. The discovered activity can be divided into four phases.

The attackers gained initial access to the network by exploiting several vulnerabilities in Microsoft Exchange servers. Following the exploitation, the attackers installed the China Chopper WebShell and used it to perform a variety of tasks at each phase.

PHASE 1. In the first phase, the attackers mainly focused on reconnaissance activity, mapping out the network and identifying critical assets. In addition, they deployed other tools that allowed them to harvest credentials, move laterally in the network, and exfiltrate data. Initially, the attackers staged many of their tools in the $RECYCLE.BIN folder, in an attempt to hide them from users and potentially avoid automatic detection by certain security tools.

For reconnaissance the following tools were used: net, query, whoami, tasklist, hostname, and ping. In addition, the following scripts were employed:

- “test.bat” to execute PortQry, a command-line utility that helps troubleshoot TCP/IP connectivity issues that reports the status of TCP and UDP ports on a remote machine. It was renamed to “psc.exe” by the attacker, probably in an attempt to avoid detection.
- “psloglist.bat” runs Microsoft’s Sysinternals PsLogList tool and saves security logs for the last 10 days.

To steal credentials the attackers used PowerShell Empire Invoke-Mimikatz. The threat actors used compromised credentials for lateral movement and privilege escalation.

To move laterally in the network, the threat actors used:

- Cobalt Strike
- WMI and Net Use: the attackers used the command “net use” to configure connections to shared resources on the network, and to copy their tools to different systems. After the tools were copied, the attackers were able to execute them remotely using WMI and by creating scheduled tasks remotely to run them.

In an attempt to hide the contents of the stolen data, the threat actors used the WinRAR tool. The data was then exfiltrated using the China Chopper WebShell. The attackers exfiltrated CDR data from telecommunication providers in order to facilitate cyber espionage against specific individuals.

The threat actors used PcShare, a publicly available backdoor with the following functionality:

- Controlling the file system

- Manipulating system services
- Uploading and downloading files
- Manipulating processes
- Manipulating the Windows Registry
- Executing arbitrary commands using Windows CMD Shell
- Rebooting/shutting down the system
- Displaying message boxes to the user

In most cases, the attackers used the DLL side-loading technique to load PcShare. In some cases, the backdoor loader was executed directly via rundll32.exe. Using PcShare gave the attackers additional capabilities such as conducting reconnaissance activity to collect information about the endpoint and network; searching for security tools and attempting to disable or kill their processes; creating scheduled tasks for the Cobalt Strike loader; using PowerShell to alter the creation time of the Cobalt Strike loader and payload files (timestomping); and executing the Cobalt Strike loader.

In order to maintain persistence in the network, the attackers installed SoftEther VPN, which they renamed to "oracll.exe" in order to evade detection.

PHASE 2. In addition to the activities performed in the first phase such as reconnaissance or the use of PcShare and WMI, the attackers also used tools that were not used by them in the previous phase.

- Local Group, a tool for adding and enumerating users in a domain.
- Mimikatz, this time using a DLL search order hijacking technique: the attackers replaced the legitimate DLL "mscorsvc.dll" and then executed the binary "mscorsvw.exe" which loads this DLL. The DLL performed pass-the-hash and credential dumping and performed some reconnaissance commands using "net user".

PHASE 3. In the third phase, the threat actors added the following tools: NBTScan, Dump Event Log tool, and a new Mimikatz executable. The attackers ran a script named "a.bat" to dump "ntds.dit."

The attackers extended their reconnaissance activity in phase three by executing NBTScan, query.exe, and dsget.exe.

PHASE 4. The only addition observed between phase four compared to previous phases is that the attackers once again used a different Mimikatz executable.

APT10 is a Chinese cybercriminal group active since at least December 2009. The group carries out attacks to primarily spy on construction, engineering, aerospace, telecommunications, and government organizations. Japanese organizations have been affected the most.

APT name	Regions attacked	Operation start
APT27	Central Asia, Middle East, Israel	2019

Between 2019 and 2020, threat actors conducted attacks against targets in the Middle East and Central Asia. In July 2021, security researchers discovered attacks against Israeli government institutions, IT providers and telecommunications entities that began in January 2019.

The threat actors used a number of new techniques in their attack in this region. Some specialists single out this activity as that of a separate group, UNC215; however, some of the indicators and TTPs were earlier attributed to APT27.

Different attack stages involved the following:

- Initial reconnaissance: CVE-2019-06-04, CVE-2017-11882, CVE-2018-0802, CVE-2018-0798.
- Establishing a foothold: webshells ChinaChopper, AWEN, Seasharpee.

- Escalating privileges: stealing credentials using Mimikatz, WDigest, ProcDump.
- Internal reconnaissance: Windows commands (systeminfo, quser, query, nltest, dnscmd, dnsquery, net); publicly available network scanners (Advansed IP Scanner, NBTScan, Anter, NetView); non-public scanners – WheatScan; ADFind.
- Maintaining presence: backdoors Focusfjord, Hyperbro, Fjordohelper, webshells, anti.exe
- Moving laterally: RDP using compromised credentials, downloading payload together with PowerShell, Certutil, curl.exe; remote execution with PowerShell, PsExec, and Remcom.

The threat actors made effort to foil network defenders by minimizing forensic evidence left on compromised hosts, exploiting relationships with trusted third parties, continuously improving the SysUpdate backdoor (aka FOCUSFJORD), concealing C&C infrastructure, and incorporating false flags. After gaining access, the threat actors delete traces from the victim machine. The attacks involve several custom tools such as the WHEATSCAN scanner, SysUpdate (FOCUSFJORD), and FJORDOHELPER (a tool that can update SysUpdate configurations and completely remove SysUpdate from the system).

Artifacts contain false flags:

- Addition of names in local languages to SysUpdate (e.g., some samples from Israel and the UAE contained Farsi, but the terms appeared to be autotranslated).
- Another discovered sample contained Hindi and an error message string in Arabic.
- Deployment of the SEASHARPEE web shell against financial and high-tech organizations in the Middle East and Asia. The SEASHARPEE web shell was developed and used by Iranian APT actors until the code was leaked online in March 2019; a few weeks later APT27 used it in their attacks.

The threat group leveraged trusted third parties in a 2019 operation targeting an Israeli government network. They were able to access their primary target via RDP connections from a trusted third party using stolen credentials and used this access to deploy and remotely execute the SysUpdate malware.

APT27 is a Chinese cybercriminal group known since 2010. The group targets the aerospace, government, defense, technology, energy and manufacturing industries. It has recently started actively using ransomware in their attacks, with a focus on financial gain.

APT name	Regions attacked	Operation start
Donot Team	-	2020

Group-IB specialists analyzed infrastructure used by Donot Team and identified patterns in its registration, which helps track new domains they register. These domains are used as C&C servers for Android malware (Donot Android Trojan).

The specialists discovered malicious .apk files that were distributed under the guise of legitimate chat applications or entertainment programs (chatlook, qmedia, HQ Movies, buzz chat, go chat, Pvt chat).

Donot Team is an APT group active since at least 2016. The attackers hunt for confidential information and intellectual property. The hackers' arsenal includes tools for attacks on Windows and Android. They have used YTY malicious tools and custom malicious APK applications. In addition, the threat actors periodically update their tools to make detection less likely.

APT name	Regions attacked	Operation start
Dark Halo	Slovakia, Czech Republic, USA, Germany, UK, Canada	December 2020

In the summer of 2021, security specialists discovered Dark Halo attacks targeting Slovakia. The campaign was active since at least February 2021 and was still active in July 2021. The threat actors sent out phishing emails posing as the Slovak National Security Authority. On March 23, 2021, someone submitted a file called "AktualizC!ciu.img" to a public sandbox. The file was submitted for analysis from Slovakia. Interestingly, the volume name contains "NBU," which is an abbreviation of the National Security Authority in Slovakia. The sample contains two files: "AktualizC!ciu.lnk" and "diassvcs.dll." The DLL file is a loader/packer with some anti-analysis protections enabled. The unpacking routine consists of decryption loops followed by calls to the VirtualProtect function and to the unpacked payload itself. The payload is a Cobalt Strike beacon.

Another file was also discovered ("invitation.iso"). It was created on February 17 and has a similar structure. It is believed that at least some of the discovered files were distributed in phishing emails as attachments. In particular, one such email was sent to an employee of a Czech subsidiary of the Taiwanese electronics manufacturer Foxconn.

Security researchers discovered new activity of DarkHalo, which they say was mostly unsuccessful, with the majority of the targets not being successfully compromised. At least three unnamed entities, however, were compromised. The attacks were targeted primarily at IT companies and, to a lesser extent, government and non-governmental organizations, think tanks, and financial services. The activity was largely focused on the US and, to a lesser degree, the UK, Germany, and Canada. A total of 36 countries were targeted.

The threat actors used password-spray and brute-force attacks. The researchers detected information-stealing malware on a machine belonging to one of their customer support agents with access to basic account information for a small number of customers (subscription to Microsoft services, contact details for invoices, services paid by customers, etc.). The threat actors gained access to the machine in the second half of May and used this information to launch attacks as part of their broader campaign. The researchers say the support agents are configured with the minimal set of permissions. No other details or indicators of compromise have been disclosed.

In September 2021, security researchers published information about DarkHalo's post-exploitation backdoor called FoggyWeb. This backdoor was used to remotely exfiltrate the configuration database of compromised AD FS servers, decrypted token-signing certificate, and token-decryption certificate, as well as to download and execute additional components. Use of FoggyWeb was observed in the wild as early as April 2021.

In addition, in late September other researchers discovered a backdoor called Tomiris, which is similar to DarkHalo's GoldMax malware. Tomiris was discovered when the researchers investigated DNS hijacking affecting several government zones of a CIS member state between December 2020 and January 2021. The backdoor's goal is to deliver additional malware to the victim machine from the C&C server. In addition, several samples could exfiltrate recent files with certain extensions.

To deliver the backdoor, the cybercriminals use DNS hijacking to redirect traffic from the target organizations' mail servers to their own malicious sites (probably by obtaining credentials for the control panel on the site of the domain name registrar). That way, they can lure clients to a page that looks like the real mail service's login page. When somebody enters credentials on the fake page, the malefactors immediately get those credentials. In some cases, the website showed a message saying that a security update had to be installed, without which it would be impossible to continue using the service. The Tomiris backdoor was downloaded as the "update."

DarkHalo has been active since at least 2019. The group carried out a global supply-chain attack against the customers of SolarWinds by creating a trojanized version of a software update, which was named sunburst.

APT name	Regions attacked	Operation start

Patchwork	Pakistan	April 2021

In July 2021, a malicious decoy document was discovered. The document contains a woman's information from a dating website. Judging by the town mentioned in the document, Peshawar, the attack targets Pakistan. The document contains a VBS, which, when launched, initiates the loading of two embedded files. All the strings are XORed using 0xA key.

One of the embedded files is a dropper for the Bozok RAT; to launch the RAT, a scheduled task is created. The second file is the final payload: BozokRAT.

In August 2021, security researchers discovered a two-step phishing attack against the Pakistani military, which started in April. During the first phase, an email without a malicious payload containing content copied from a legitimate Pakistani newspaper's article was sent to the target. The sender address, which was spoofed, impersonated the PR wing of the Pakistani Armed Forces. Two days later, the threat actors sent a second email, purportedly a warning about the Pegasus spyware. The sender address impersonates a service similar to that on the first email.

The email has two links:

- A short link to an encrypted malicious document and a password for decryption will be sent to the target.
- An Unsubscribe link; clicking on it will download a document from the server.

After entering the password mentioned in the message, a document containing macros is displayed on the screen. If the victim enables macros, the malicious code will be loaded. If the victim enters any phone number and clicks on "SUBMIT," the text field will be replaced by the message "Phone Number Not Found." Behind the scenes, a file called "skfk.txt," is created in the temporary directory and then loaded in memory via PowerShell.

The attack is conducted in multiple stages:

- Stage 1 is a simple download and execute program. It downloads an ASCII file from the server and converts it into binary before loading it on to the memory and jumps to a dynamic function.
- Stage 2 is a .NET DLL file that downloads a third file from the same domain, converts it to binary, and then creates a scheduled task to load it.
- Stage 3 is similar to stage 1, with the only change being the URL to retrieve the next stage.
- Stage 4 is the final payload. It is never written in clear text to the file disk and is immediately loaded in memory. It is designed to steal documents and images with the following extensions: .txt, .pdf, .png, .jpg, .doc, .xls, .xlm, .odp, .ods, .odt, .rtf, .ppt, .xlsx, .xlsm, .docx, .pptx, and .jpeg.

When a file matching one of the listed extensions is found, its MD5 hash is calculated and compared to an exclusion list retrieved from C&C. If the hash is not listed, the file is sent via the C&C to a directory named after concatenation of the machine name and the username.

The researchers came across another campaign delivering the same payload but impersonating the Pakistani Defense Housing Authority. The lures used in an older campaign from April 2021 impersonated the Federal Board of Revenue. There were minor differences in tools, tactics, and procedures: the malicious document was directly attached to the spear phishing email — still encrypted — and the decryption password was sent in a different email. The first stage was the same, but the second stage contained the final payload, which was once again a file stealer with the exact same structure (a .NET DLL). Instead of exfiltrating the files through PHP scripts, an FTP server was used.

Patchwork has been active since at least 2013 and has been attacking organizations in industries connected with diplomatic missions and government entities for the purposes of espionage and information theft.

APT name	Regions attacked	Operation start
Sidewinder	Myanmar, Afghanistan, Nepal	November 2020

Analysis of Sidewinder's infrastructure revealed malicious files that were used as a backdoor. Launching such a file enables an attacker to remotely execute commands on the infected computer, collect information about the computer and the network, move across the network, and more.

Sidewinder employed an interesting technique where a malicious file constantly accessed a text file on the C&C server; the file is used by the attacker to write commands that should be executed.

Based on previous analyses and knowledge about Sidewinder's use of Telegram bots, another Telegram bot was discovered, where data stolen from infected victims was sent. Analysis of messages in the bot revealed attacks against government organizations and entities in Myanmar, Afghanistan, and Nepal.

In addition to the stolen data, emails that were used in a phishing mailout were discovered. Group-IB specialists identified the victims and notified them of the attacks.

The C&C used in the attacks were disguised as legitimate domains for Microsoft services.

SideWinder has been active since at least 2012. The group engages in cyber espionage against targets in South Asian government entities (governments, the military). The group's attacks target both Windows and Android users.

APT name	Regions attacked	Operation start
Gamaredon	Ukraine	January 2021

In Q3, Group-IB specialists discovered new as well as previously unknown attacks by the Gamaredon group.

The attackers used a tried and tested technique:

1. A malicious Word document with specially crafted information targeting the victim. The document downloads a .dot template from a server.
2. The .dot template contains an obfuscated VBS script (which is launched using wscript.exe), collects information, and communicates with the C&C server.
3. The third stage involves Gamaredon tools such as Gamaredon.Stealer or Gamaredon.MACStealer.

A new third-stage tool was discovered. It was dubbed Gamaredon.ResidentDownLoader. The tool does not have stealer functionality and, unlike the stealer, is written to the Startup folder, collects data about computer components, and sends this data to the server. Gamaredon.ResidentDownLoader can then receive commands from the C&C server, which it saves to a file for subsequent execution.

Possible attacks that took place in late May against Ukraine's Security Service and Kyiv City Prosecutor's Office.

The primary target of Gamaredon's summer campaign was the infrastructure of the city of Sievierodonetsk. Potential targets included the prosecutor's office, the police, and universities.

In addition, malicious documents that may have been used in an attack against the energy sector and linked to the news about the Ukrainian president's visit to the United States were discovered. The period

between the time the news came out and the malicious documents were created is so small that it suggests that Gamaredon is active in analyzing news resources to conduct phishing attacks more efficiently.

Further, domains and theme-specific malicious files that Gamaredon used in attacks against Ukrainian government entities were discovered.

Gamaredon is presumably a Russian threat group active since at least 2013. The group's aim is to spy on Ukrainian government officials, the military, diplomats, law enforcers, and journalists.

APT name	Regions attacked	Operation start
APT41	USA, Taiwan, India, Malaysia, Hong Kong, UK, Ireland, Thailand, Vietnam, Philippines, Indonesia	2020

Since 2021, APT41 conducted campaigns that Group-IB specialists named ColunmTK, DelaylinkTK, Gentle-Voice, and Mute-Pond. Organizations in the US, Taiwan, India, Malaysia, Hong Kong, the UK, Ireland, and Thailand have fallen victim; they include a logistics company, media, government organizations, a Taiwanese electronics manufacturer and a Taiwanese healthcare center, a Chinese software manufacturer, a Vietnamese electronic payment system and a Vietnamese educational institution, hotels and software manufacturers in the US, and an Indian company in the airline industry. A total of 13 organizations were compromised and 80 were targeted.

Group-IB specialists found that APT41 attackers used the Acunetix vulnerability scanner to detect potentially weak points in target systems to then exploit them. It was discovered that as an initial vector the threat actors used the publicly available tool sqlmap. The attackers used this tool to detect and perform SQL injections in target systems. This tool enabled them to obtain various confidential files such as database configurations, password storage spaces, and user data, as well as to obtain rights to execute commands on remote systems. It was found that in at least two analyzed incidents, the threat actors downloaded and executed Cobalt Strike payload after executing certain commands using sqlmap.

After the attackers get access to the target system, they try to spread to other computers available in the local area network to search for and exfiltrate accounts, confidential documents, and private repositories of developers.

Various researchers discovered attacks called RedEcho, RedFoxtrot, and TAG-22. According to our data, APT41 is behind these attacks. This is evidenced by overlaps in the network infrastructure, motivation and TTPs.

In addition, various researchers observed attacks by APT41 in which sqlmap was used to penetrate target systems (the campaign was called Earth Baku). Such attacks took place since at least 2021 and targeted India, Indonesia, Malaysia, the Philippines, Taiwan, and Vietnam. As an initial vector, the researchers mention the use of the ProxyLogon vulnerability CVE-2021-26885 in Microsoft Exchange Server to upload web shells to target servers. These attacks also involved the group's custom tools such as StealthVector and StealthMutant.

Researchers also discovered another custom tool of the group, which was dubbed BIOPASS. The tool is a typical RAT; it was used in attacks against visitors to Chinese gaming websites. To distribute malware, the threat actors use malicious JavaScript code planted by attackers on the tech/chat support pages of Chinese gambling-related sites. The script redirects users to pages containing infected Adobe Flash Player and Microsoft Silverlight installers.

APT41 might also be behind the attack against a Mongolian certificate authority. The threat actors compromised the MonPass certificate authority's server and inject a Cobalt Strike–based backdoor into

the official client. Analysis of this incident revealed that the server had been compromised at least eight times and various backdoors and web shells were discovered on it.

APT41 is a Chinese state-sponsored threat group whose goals are cyber espionage and financial gain. The group has been active since at least 2007. APT41 specializes in stealing digital certificates to use them in activities related to stealing user data (cyber espionage) and deploying crypto miners and ransomware on target devices. The group's earlier goals included manipulation of currencies in online games and intellectual property thefts.

APT name	Regions attacked	Operation start
IndigoZebra	Afghanistan, Kyrgyzstan, Uzbekistan	2014

July 2021, security researchers discovered an attack targeting the Afghan government, which was part of a campaign targeting other Central Asian countries since at least 2014.

The threat actors sent emails posing as an employee of the Administrative Office of the President in Afghanistan to the employees of the Afghanistan National Security Council (NSC). The email asked the recipient to review modifications in a document related to an upcoming press conference of the NSC. The email contains a password-protected RAR archive, with the password provided in the email. The archive contains an executable file that acts as a dropper. When executed, the dropper opens a file on the victim's desktop in order to hide its activity since the victim is expecting to see a .doc file being open. As a result of its execution, the dropper drops the BoxCaon backdoor. The backdoor's capabilities include downloading and uploading files, running commands, and sending the attackers the results. The backdoor utilizes Dropbox as a C&C server.

Once the C&C communication is established, the threat actors conduct reconnaissance on the victim's machine. To do so, they download and execute nbtscan, use built-in Windows utilities, and access the victim's files.

The researchers believe that BoxCaon is a variant of the xCaon program. Other discovered samples, which are HTTP variants of xCaon, were used in attacks against political entities in Kyrgyzstan and Uzbekistan.

IndigoZebra is a Chinese APT group active since at least 2014. Victims have been detected in the government sector in countries that are members of the Commonwealth of Independent States (CIS). During their latest activity, the threat actors expanded their attacks to Afghanistan. Their attacks have involved Poison Ivy and xCaon and its BoxCaon version.

APT name	Regions attacked	Operation start
Kimsuky	South Korea	June 2020

In Q3, security researchers continued to detect Kimsuky's various types of decoy files, some of which have been used since 2020.

- One type of decoy file has been used since June 2020; such files relate to current events and contain VBA with simple obfuscation. After execution, a script is downloaded from a server to collect information and send it back. Following that, data is received from the server for execution.
- Another type of document had been sent out since December 2020. The topic is Biden's policies and military matters. When the document is opened and a macro is enabled, VBA code saves deobfuscated data as an .xml file and puts it in %AppData%\Roaming\Microsoft\Templates.

During the analysis, links were unavailable but it is believed that the next stages are used to collect information or download additional malicious programs.

- Another type of attack had been used since December 2020. When the victim opens a document and enables a macro, a .dll is downloaded from a OneDrive cloud disk. The payload drops a next-stage VBS script. The task of the script is to request data from OneDrive, decrypt it, and execute it in memory. The script, executed in memory, downloads and executes the next .bat payload, whose goal is to decrypt and execute a .tmp file. The latter is used to collect information.
- The fourth type of file, used since June 2021, employs a new way of storing malicious scripts: they are saved on blog web services. When the victim enables a macro, encoded data is saved to an .ini file for subsequent execution; to ensure its persistence an .lnk is created in the Startup folder. The .ini file accesses a pre-created page to receive an obfuscated script, which will be used for information collection purposes. One such attack in June 2021 involved a phishing mailout distributing a .docx file related to an inter-Korean summit.

Kimsuky (also known as Velvet Chollima and Thallium) is a hacker group believed to be based in North Korea. The group has been actively attacking entities in South Korea since 2010 but has lately been expanding the geographical scope of their attacks.

APT name	Regions attacked	Operation start
Bitter	China	2021

In July 2021, researchers published information about several attacks conducted in 2021 by Bitter against military, trade and energy organizations.

In their attacks, the threat actors sent out phishing emails with a CHM attachment and the subject “meeting agenda.” Opening the attachment automatically launches a malicious script contained in it and creates a scheduled task to run an .msi file. The .msi file is used to drop a downloader responsible for obtaining a series of plugins from the server. It was found that the following plugins were used: plugins for remotely managing files and executing commands; plugin for stealing credentials from browsers; keylogger; and stealers asms and sthost. The asms stealer is used to steal files from the victim’s hard drive; files in the CD-ROM drive, if present, are also sent to the server. The sthost stealer is used to collect basic information from the host and collect certain files.

The BITTER group has been active since at least 2015 and is believed to represent Indian interests. BITTER APT campaigns primarily target China, Pakistan, and Saudi Arabia. The group’s arsenal includes the similarly named remote access Trojan BitterRAT and a downloader malware family called ArtraDownloader.

APT name	Regions attacked	Operation start
Bandidos	Venezuela	2015

In July, security researchers discovered a campaign called Bandidos, which had been carried out since 2015 for espionage purposes and targeted Spanish speaking countries, with the vast majority of attacks targeting Venezuela. The threat actors’ main interests were corporate networks in the manufacturing, construction, healthcare, and retail. The campaign involved a version of the Bandook RAT, which is presumably used by various threat actors and distributed by developers as malware as a service.

The attack starts with an email with a malicious PDF attachment. The attachment contains a shortened link (Rebrandly or Bitly) and a password for opening a file the link leads to. The shortened link redirects

the victim to a cloud storage service from where a RAR file is downloaded. The archive contains a dropper that injects the Bandook RAT into an Internet Explorer process.

APT name	Regions attacked	Operation start
Mustang Panda	Myanmar, Philippines, South Asia	October 2020

July 2021 saw the discovery of a major campaign in South-East Asia with at least 100 victims in Myanmar and 1,400 victims in the Philippines. Specialists at Kaspersky named the group responsible for the campaign LuminousMoth. The campaign dates back to at least October 2020 and may still continue.

The infection vectors were malicious emails containing a DropBox link to a RAR archive that masquerades as a Word document, with subsequent DLL side-loading. The malware then established persistence in the system, spread to USB and other removable devices, and downloaded a Cobalt Strike beacon. As a post exploitation tool, the threat actors used a stealer that masqueraded as Zoom and a tool that steals cookies from the Chrome browser.

LuminousMoth's TTPs are very similar to those of Mustang Panda. Both groups use the same tools and techniques and attack the same region. In addition, infrastructure overlaps were found. Based on this, the specialists believe with medium to high confidence that Mustang Panda is behind the attacks.

In late July, other researchers published a report about a previously unknown PlugX variant called Thor, which was used after exploitation of zero-day vulnerabilities in Microsoft Exchange known as ProxyLogon (CVE-2021-26855 and CVE-2021-27065). The researchers attributed the attack to Mustang Panda based on the use of PlugX, DLL side-loading, and infrastructure overlaps.

Mustang Panda is a Chinese threat group discovered in 2017 but believed to have been active since 2014. The group previously used the Mongolian language and topics as lures and actively used PlugX and Poison Ivy. Lately, however, the group has used Cobalt Strike, switched to South Asia and also conducted campaigns related to the 5G industry.

APT name	Regions attacked	Operation start
Turla	USA, Germany, Afghanistan	2020

In September 2021, security researchers discovered a previously unknown piece of malware called TinyTurla, which had been used by the Turla group since 2020 in attacks against organizations in the US, Germany, and Afghanistan. It must be noted that in the case of Afghanistan, the attacks targeted the country's government before the Taliban took it over.

TinyTurla is a second-chance backdoor used to maintain access to the system, even if the primary malware is removed. It could also be used as a second-stage dropper to infect the system with additional malware. The backdoor comes in the form of w64time.dll and is installed as a Windows Time service being disguised as a legitimate one. The threat actors used a .bat file to install the backdoor and set configuration parameters in the registry.

First, the ServiceMain function is used, which executes a function "main_malware," which includes the backdoor code. The backdoor reads its configuration from the registry and saves it.

The backdoor code is quite simple and supports a few functions. The backdoor goes through the list of C&C servers stored in its registry configuration parameter until it finds one responding. If none of the C&C servers respond, the backdoor waits for some time and then tries to reach the configured C&C servers, again. If a connection to one of the configured C&C servers was set up successfully, the backdoor stays in

the inner while loop and checks for commands with certain time intervals. The following C2_command_codes were discovered in the backdoor code:

- 0x00:'Authentication'
- 0x01:'Execute process'
- 0x02:'Execute with output collection'
- 0x03:'Download file'
- 0x04:'Upload file'
- 0x05:'Create Subprocess'
- 0x06:'Close Subprocess '
- 0x07:'Subprocess pipe in/out'
- 0x08:'Set TimeLong'
- 0x09:'Set TimeShort'
- 0x0A:'Set new 'Security' password'
- 0x0B:'Set Host(s)'

Turla is a Russian-speaking cybercriminal group believed to have been active since 2007. The main goal of Turla's attacks is to steal information from diplomatic, government, military, educational, research, and pharmaceutical organizations.

APT name	Regions attacked	Operation start
WildPressure	Middle East	May 2019

In July 2021, security researchers discovered a new version of the Milum malware used by the WildPressure group. The attacks targeted the oil and gas industry in the Middle East. The first activity involving a C++ version of Milum dates back to 2019. In addition to versions written in C++, the experts observed attacks involving similar versions written in Visual Basic Script and Python. The latter can infect both Windows and macOS. All three versions are able to download and execute commands from the operator and collect information. It is thought that the malware is still being developed. In addition to commercial VPSs, the operators this time used compromised legitimate WordPress websites.

WildPressure is an APT group that has been active since 2019 and mostly attacking industrial organizations in the Middle East. For its attacks, the group uses versions of the Milum Trojan that are written in various programming languages and are still being developed.

APT name	Regions attacked	Operation start
SideCopy	India, Afghanistan, Iran, Jordan,	2019

In July 2021, security researchers published information about the activity of the SideCopy group, which mimics the TTPs of SideWinder to deploy their own tools.

SideCopy threat actors' earliest discovered infection chain consisted of an LNK file that pulled down and executed an HTA. This HTA would decode and instrument a loader DLL in memory to drop CetaRAT.

In 2020 and 2021, the threat actors improved their infection chains. Infections still began with malicious LNK files delivered to the victims. However, what followed was a combination of three HTA files, three loader DLLs, two instances of CetaRAT in some cases, and Allakore. The threat actors also adopted the practice of displaying a decoy document, as opposed to the 2019 attacks where no decoys were displayed.

In another infection chain, the attackers distributed a self-extracting RAR archive that consisted of a malicious VB script, njRAT, and a PDF decoy related to the Indian Army and government.

In yet another infection chain, the attackers hosted a malicious archive (ZIP) on an attacker-controlled website. The ZIP file contained an MSI file posing as a legitimate installer. On installation, the malicious MSI would install Allakore RAT.

SideCopy has been active since at least 2018 and used various malware:

- CetaRAT
- DetaRAT, a C#-based RAT that contains several RAT capabilities similar to CetaRAT.
- ReverseRAT, a C#- based reverse shell that also monitors removable drives. It is based on CetaRAT.
- MargulasRAT, a RAT that masquerades as a VPN application from India's National Informatics Centre (NIC).
- ActionRAT, a Delphi-based RAT that looks similar to Allakore.
- Allakore, a well-known Delphi-based RAT.
- Lilith, a C++-based RAT first observed in 2016. SideCopy used a customized version of Lilith in early 2019.
- EpicenterRAT, a commodity RAT that has been used by SideCopy since 2018.

In addition, SideCopy utilizes plugins to carry out specific malicious tasks on the infected endpoint: a file management component, keyloggers, browser credential stealers, Nodachi (Golang-based plugins with reconnaissance and file-stealing abilities).

In August 2021, security researchers published information about updated versions of SideCopy's malware. In particular, ReverseRAT 2.0 was discovered, which was fitted with capabilities to take photos via webcams from infected machines and to steal files from USB connections. An updated version of the preBotHta loader was uncovered. The researchers also observed a program called NightFury. It was found that the programs had been used since late June 2021 in attacks in Afghanistan, Jordan, India, and Iran.

SideCopy is a Pakistani APT group that mimics the TTPs of SideWinder. It has been active since at least 2019 and has mainly targeted government and military entities in India.

APT name	Regions attacked	Operation start
APT35	Middle East	January 2021

In July, security researchers discovered an APT35 campaign dubbed Operation SpoofedScholars that targeted experts in Middle Eastern affairs from think tanks, senior professors from well-known academic institutions, and journalists specializing in Middle Eastern coverage.

In their campaign, the threat actors masqueraded as UK scholars with the University of London's School of Oriental and African Studies (SOAS). The mailouts purported to be by Hanns Kendel and Tolga Sinmazdemir. The attackers send their victims phishing links for registering for online conferences; they do so to steal Google, Microsoft, Facebook, and Yahoo credentials. To appear more authentic, the phishing infrastructure involved a legitimate but compromised website belonging to the University of London's SOAS radio.

In early 2021, the threat actors sent out an email trying to entice their target with a prospective invitation to an online conference and strived to connect with the individual via phone to discuss the invitation. In response, the target asked for a written proposal with details to be emailed. In the end, the threat actors emailed a detailed invitation to the fake conference containing a phishing link. They insisted that the victim immediately log in to the system to register; they did so to immediately validate the obtained credentials manually.

The threat actors later abandoned the practice of initially establishing contact with the target and started sending out phishing links in the first email.

In addition, the researchers discovered at least one case in which the threat actors tried to gain access to a target's personal email account.

The Iranian threat group APT35 (also known as Phosphorus, Charming Kitten, Ajax Security Team, Newscaster, Group 83, and Parastoo) has been carrying out attacks since at least 2013. The group focuses on individuals of interest to Iran who work in the fields of academic research, human rights, and media, with most victims located in Iran, the US, Israel, and the UK.

APT name	Regions attacked	Operation start
DEV-0322	USA	2021

In July 2021, security researchers detected a zero-day vulnerability, CVE-2021-3521, being used by the Chinese group DEV-0322 to attack SolarWinds Serv-U FTP software. Successful exploitation of the vulnerability can enable attackers to remotely run arbitrary code with privileges, allowing them to perform actions such as installing and running malicious payloads, or viewing and changing data.

The threat actors piped the output of their cmd.exe commands to files in the Serv-U \Client\Common\ folder, which is accessible from the Internet by default. They also added a new global user to Serv-U, effectively adding themselves as a Serv-U administrator, by manually creating a crafted .Archive file in the Global Users directory.

DEV-0322 is a Chinese group that targets entities in the US defense sector and software companies. The threat actors use VPN solutions and compromised consumer routers in their infrastructure.

APT name	Regions attacked	Operation start
APT37	South Korea, Russia	March 2021

In Q3, security specialists discovered that the website of a South Korean online newspaper that focuses on issues relating to North Korea had been compromised. Malicious code on the website was observed between at least March 2021 and June 2021.

The threat actors used CVE-2020-1380, an exploit for Internet Explorer. When a user visited the compromised news resource using Internet Explorer, an additional JavaScript file would be loaded from an attacker-controlled domain. Successful exploitation of the vulnerability results in a blob that contains a hex-encoded representation of a Cobalt Strike stager, which is decoded and executed. On another occasion, CVE-2021-26411 was used, which is another exploit targeting Internet Explorer and legacy versions of Microsoft Edge.

In another case, the attackers used BLUELIGHT, a custom malware family. It is likely that BLUELIGHT was used as a secondary payload. The malware family uses different cloud providers to facilitate C&C activities. The following commands are supported:

- Execute downloaded shellcode.
- Download and launch an executable, then upload program output.
- Harvest cookies and a password database for Win7 IE, Win10 IE, Edge, Chrome, and Naver Whale.
- Recursively search a path and upload file metadata.
- Upload files as a ZIP archive.
- Terminate the file upload thread. Uninstall the implant.

In August, researchers published details of an attack in which the BLUELIGHT malware was delivered to a victim alongside RokRAT. Much like BLUELIGHT, this malware family uses cloud services for all communications, supporting PCloud, Yandex, Dropbox, and Box. RokRAT is able to perform a number of functions, including keylogging and extraction of clipboard data, collection of specific filetypes, and downloading/executing further payloads.

In late July 2021, security specialists identified a spear-phishing campaign pushing the Konni RAT to target Russia. Konni has potentially been linked to APT37. Two documents written in the Russian language were weaponized with the same malicious macro. One of the lures is about trade and economic issues between Russia and the Korean Peninsula. The other one is about a meeting of the intergovernmental Russian-Mongolian commission. Opening the document launches a macro that uses a shell function to execute a cmd command that gets the current active document as input and looks for a certain string in it, then writes that sting a .js file. The script looks for two patterns in the document, decodes them, and saves them to "yy.js" and "y.ps1." After the output files are created, they are executed using Wscript and Powershell. The Powershell script is used to download a .cab file from a certain URL. The .cab file contains 5 files: "check.bat," "install.bat," "xmlprov.dll," "xmlprov.ini," and "xwtpui.dll." The yy.js is used to execute "check.bat," which checks if cmd is launched as administrator. It then executes "xwtpui.dll" by passing three parameters to it, one of which is "install.bat." "Install.bat" is responsible for installing "xmlprov.dll" as a service. "Xmlprov.dll" is an obfuscated Konni RAT payload. The RAT starts by collecting information from the victim's machine (systeminfo, tasklist) and saving it to .tmp files. In the next step, each of the the collected .tmp files is converted into a .cab file, then encrypted, and sent to the attacker server in an HTTP POST request. Commands from the server are then waited for.

APT37 (also known as Group123, Reaper, ScarCruft, Geumseong121, Red Eyes, Ricochet Chollima, Venus 121, Thallium, Hermit, and KONNI) is a threat group believed to be acting in the interests of the North Korean government since at least 2012. The group mainly targets government, defense, military, and media organizations in South Korea. Targeted sectors include the healthcare, chemicals, manufacturing, aerospace, and automotive industries.

APT name	Regions attacked	Operation start
Sourgum	Palestine, Israel, Iran, Lebanon, Yemen, Spain UK, Turkey, Armenia, Singapore, Indonesia, Russia, Czech Republic, Armenia, Cyprus, Austria, Saudi Arabia, Slovenia	2021

In July 2021, specialists discovered an infrastructure linked to spyware by SOURGUM (also known as Candiru). Candiru is an Israeli organization founded in 2014 that develops spyware and sells it to government sector customers.

Many identified domains masqueraded as human rights organizations, media outlets, technology companies, and international, political and civil associations. Victims have been found in Palestine, Israel, Iran, Lebanon, Yemen, Spain, the UK, Turkey, Armenia, and Singapore. Based on domain analysis, the researchers believe that there could also be victims in Indonesia, Russia, the Czech Republic, Cyprus, Austria, Saudi Arabia, and Slovenia.

The specialists uncovered information about tools belonging to Candiru. The company has exploits for zero-day vulnerabilities CVE-2021-31979 and CVE-2021-33771. In addition, malware called DevilsTongue was discovered. It is a complex modular multi-threaded piece of malware written in C and C++. The main functionality resides in DLLs that are encrypted on disk and only decrypted in memory. Configuration and tasking data is separate from the malware. DevilsTongue's capabilities include file collection, registry querying, running WMI commands, querying SQLite databases, stealing messages saved in the Signal app, and stealing cookies and passwords from Chrome, Internet Explorer, Firefox, Safari, and Opera. DevilsTongue can also send messages from social media and email accounts that are logged in to on the victim's machine.

SOURGUM (aka Candiru) is an Israeli organization founded in 2014 that develops spyware and sells it to customers in the government sector.

APT name	Regions attacked	Operation start
APT-C-61	Pakistan, Bangladesh	January 2020

July 2021 saw the discovery of APT-C-61, a previously unknown group that had conducted attacks against the military industry, scientific research, and national defense in Pakistan and Bangladesh since at least 2020.

As a penetration vector, the threat actors mostly used phishing emails with an archive attached. The archive contained a .docx file and a .pdf file that related to the content of the email or one that, when opened, displayed an error to the user. After being opened, the .docx uses DDE (dynamic data exchange) to execute a PowerShell script. The script performs several tasks: downloads malicious programs, ensures their persistence, and exfiltrates files.

One of the downloaded malicious scripts is a Python script that supports the commands cd, download, exit, and upload. To avoid traffic being detected when exfiltrating files, the threat actors performed compression using 7za.exe and then uploaded them to Google Cloud Disk using the rclone utility.

APT-C-61 (aka Tengyun snake) is a South Asian group active since at least 2020. Victims have been found in the military industry, scientific research, and national defense in Pakistan and Bangladesh. In their attacks, the group uses tools for stealthy file exfiltration. Their infrastructure mostly consists of legitimate services and cloud technologies.

APT name	Regions attacked	Operation start
APT40	-	-

On July 19, 2021, the United States Department of Justice published an indictment against four Chinese nationals for hacking companies, universities and government entities worldwide. The defendants are believed to be part of a large group called APT40 and are also believed to have established a company called Hainan Xiandun Technology Development Co., Ltd. to disguise their attacks.

The indictment alleges that three defendants were officers in the Hainan State Security Department (HSSD), a provincial arm of China's Ministry of State Security (MSS): Ding Xiaoyang (丁晓阳), Cheng Qingmin (程庆民) and Zhu Yunmin (朱允敏). The indictment alleges that the fourth defendant, Wu Shurong (吴淑荣), was a computer hacker who, as part of his job duties at Hainan Xiandun, created malware, hacked into computer systems.

APT40 (also known as Leviathan, TEMP.Periscope, TEMP.Jumper, Bronze Mohawk, and Mudcarp) is a cyberespionage group sponsored by China and active since at least 2013. The threat actors hack the

networks of defense organizations and steal confidential technical drawings and other information that can be used to modernize the Chinese navy and influence foreign elections.

APT name	Regions attacked	Operation start
PROMETHIUM	Syria	May 2021

In August, security researchers discovered the first case of the PROMETHIUM group using an Android Trojan. The malware was disguised as the Syrian e-gov Android application and was posted on the Syrian e-Gov website.

The discovered sample was created in May 2021 by repackaging the original app from the Syrian government. The malicious application requests additional permissions on the device to, among other things, read contacts, write external storage, ensure a wake lock, receive information about location, phone state and Wi-Fi state, and even be automatically launched after a system boot.

The Trojan uses the "Handler" mechanism to dispatch messages that trigger malicious behavior. Seven message types are supported:

- MSG_TRIG_ALARM_HEARTBEAT: When this message is received, a periodic task for heartbeat message is set.
- MSG_TRIG_ALARM_SYNC: When this message is received, a periodic task for sync message is set.
- MSG_HEARTBEAT: This message triggers the heartbeat function, which sends a request to the C&C server and receives a response with an encrypted payload containing a file with settings allowing the malware to change its behavior according to the configuration.
- MSG_SYNC: It uploads files collected from the victim's device into a .zip archive with a periodicity of 3,000 seconds.
- MSG_COLLECT: Collects data from the victim's device (contact information, information regarding available Wi-Fi networks, and files with certain extensions).
- MSG_TRIG_ALARM_COLLECT: When this message is received, a periodic task for the "collect message" handler is set.
- MSG_CONNECTIVITY: This message sends all the mentioned messages one by one.

This sample uses highly modular components to create a flexible architecture for component loading and unloading using the functions onCreate and onDestroy. The following components were discovered:

- pekmek (Crypto Manager): Uses AES to decrypt and encrypt files and strings.
- ltymcr: Contains many utility functions, such as a function to calculate unique id, parse config file, write/read shared preference, and define encryption keys.
- sadwoo: A component used as PowerWakeLock.
- phkyxc: A component used as WifiWakeLock.
- tfsdne: A wrapper used for C&C communication such as heartbeat and sync.
- itxdrx (Net Manager): A component responsible for handling HTTP protocol communication.
- Nhnhpi: A component responsible for managing the C&C server.

PROMETHIUM is a group of hackers believed to be from Turkey. The group, which was active as early as 2012, is also known as StrongPity and APT-C-41. Information about this threat group was first published in October 2016 with details about the group's attacks against users in Belgium and Italy. In 2018, the threat actors shifted their focus to a different region and targeted Turkish telecommunications companies in order to attack hundreds of users in Turkey and Syria.

APT name	Regions attacked	Operation start
APT31	France, Mongolia, Russia, Belarus, Canada, USA	January 2021

In July 2021, the French National Agency for the Security of Information Systems (ANSSI) issued an alert with indicators of compromise discovered during their analysis of a campaign against French organizations attributed to APT31. According to the agency, the threat group hijacks home routers to form a proxy mesh around its server infrastructure in order to relay and disguise the origins of their attacks. ANSSI says that the attacks started at the beginning of 2021. French officials said that APT31's proxy botnet was used to both perform reconnaissance operations against their targets and carry out the attacks themselves.

In addition, security researchers detected the group's malicious activity that took place between January 2021 and July 2021 involving a new dropper. Attacks were discovered in Mongolia, Russia, Belarus, Canada, and the US.

The main objective of the dropper is to create two files on the infected computer: a malicious library and an application vulnerable to DLL sideloading. At the second stage, the application launched by the dropper loads the malicious library and calls one of its functions. The library checks for the presence of the file "ssvagent.dll" (this is the encrypted main load downloaded from the server). If this file does not exist, the address of the control server from which the download will be performed is decrypted. The decrypted data is placed in the application memory, and control is transferred to it. The main library starts its execution by creating a package that will be sent to the server. Officially, the package is created from three parts: main heading, hash, and encrypted data. The generated package is encrypted and sent to the server. After this, malware waits for commands from the server. The commands are:

- 0x3 — get information on mapped drives.
- 0x4 — perform file search
- 0x5 — create a process, communication through the pipe
- 0xA — create a process via ShellExecute
- 0xC — create a new stream with a file download from the server
- 0x6, 0x7, 0x8, 0x9 (identical) — search for a file or perform the necessary operation via SHFileOperationW (copy file, move file, rename file, delete file).
- 0xB — create a directory
- 0xD — create a new stream, sending the file to the server.
- 0x11 — self-delete

APT31 is characterized as an actor specialized in intellectual property theft, focusing on data and projects that make a particular organization competitive in its field. Based on available data, security specialists believe that APT31 conducts network operations at the behest of the Chinese government.

APT name	Regions attacked	Operation start
Praying Mantis	USA	2021

In July 2021, security researchers discovered activity of the group Praying Mantis, which had been tracked for a year. The attacks targeted organizations in the US.

To carry out the attacks, the threat actors used a Checkbox Survey remote code vulnerability exploit (CVE-2021-27852), a VIEWSTATE deserialization exploit, and a Telerik-UI exploit (CVE-2019-18935 and CVE 2017-111317).

As the first stage, the threat actors use NodellSWeb (.NET DLL reflectively loaded module), which can operate in two different modes: IIS hooking mode and web shell controller mode. The malware provides the threat actors with the following capabilities:

- Running a set of basic functions (such as gathering system information or accessing and manipulating the file system on the machine
- Executing JScript payloads on the machine
- Dynamically loading additional modules
- Performing network related operations including HTTP and SQL traffic forwarding and an implementation of a TCP client instance

As a second stage, the threat actors employ a backdoor that uses a passive C&C channel, listening for incoming TCP connections. The tool enables the threat actors to perform various actions on the affected host, including file and directory manipulation (read, write, delete, copy, move), system information gathering, dynamic DLL loading and execution, code injection, and token manipulation.

The threat actors leveraged NodeIISWeb and ExtDLL.dll to execute additional .NET modules:

- PSRunner.dll: Provides the threat actors with the ability to run PowerShell script-blocks on a host without spawning a PowerShell process.
- Forward.dll: enables the threat actors to forward HTTP traffic to a remote host based on a given set of parameters.
- PotatoEx.dll: a .NET version of the Potato family.
- E.dll: Used by the threat actors to verify whether an exploit has successfully executed on a target IIS server.

After successful exploitation, the attackers collected credentials and used tools such as SharpHound and PowerSploit to conduct reconnaissance. The threat actors access shared folders on internal web servers over SMB using compromised domain credentials. On several occasions the threat actors dropped the NodeIISWeb web shell loader via SMB to compromise additional servers.

Praying Mantis (also known as TG1021) is an APT group that was discovered in 2021. Their attacks have targeted the US. Malware used by TG1021 includes special tools designed for hacking IIS servers, a backdoor, and several post-exploitation modules that enable the threat actors to conduct reconnaissance, escalate privileges, and move across the target network. Security researchers have found similarities to attacks by Copy-Paste targeting Australian public and private sector organizations last year, which have been linked to Chinese hackers.

APT name	Regions attacked	Operation start
Indra	Iran	July 2021

A data deleting wiper attacked Iran's railway system at the beginning of July. A system used for managing train schedules and ticket services experienced a failure. The previously unknown wiper was dubbed Meteor and the entire campaign was called MeteorExpress.

Meteor was one of three components in this attack, which included:

- Meteor: a wiper that deletes the infected computer's file system

- mssetup.exe: a file used as a screen locker
- nti.exe: a file used to corrupt the system's master boot record (MBR)

The penetration vector was not established, but specialists know that after penetrating the network, threat actors used group policies to deploy malware, delete copies, and disconnect infected hosts from local domain controllers so that system administrators could not promptly handle the consequences of the attack.

The destructive attacks targeting Iranian Railways and the Ministry of Roads and Urban Development were organized by a threat group called Indra. Experts at Check Point Research say that the group has carried out attacks against Syrian organizations and infected their systems with malware. Indra developed at least three wiper variants (Meteor, Stardust, and Comet) and used them in attacks.

The Indra group identifies itself as a group that opposes the Iranian regime.

APT name	Regions attacked	Operation start
Targeted attack against Russia	Russia	July 2021

On July 21, 2021, security researchers discovered a document called "Манифест.docx" ("Manifest.docx") that downloaded and executed two templates: one was macro-enabled and the other was an html object containing an Internet Explorer exploit (CVE-2021-26411). Executing them launches VBA RAT. The threat actors used both methods to increase the chances of infecting victims. The decoy document is a statement from a group within Crimea that voices opposition to Russia and specifically Putin's policies against that peninsula.

The RAT supports the following capabilities: collecting information about the victim, identifying the AV product running on the victim's machine, executing shell-codes, deleting, uploading and downloading files, and reading disk and file system information.

The security researchers also uncovered a panel dubbed Ekipa, which seems to be a slang term for "equipment." Victims are tracked and statistics include whether the IE exploit is successful or not. The threat actors behind the attack have not been identified.

APT name	Regions attacked	Operation start
Lazarus	South Korea, Austria, India	February 2021

Security researchers discovered an espionage campaign targeting South Korea. They found a malicious sample that was normal code of a Notepad++ plugin called ComparePlus, which was released as open-source code with an ability to download malicious programs.

In addition, judging by Lazarus's samples, the state-sponsored threat actors became active again: they target various organizations using phishing emails and drop text documents that use macros when downloaded and executed.

The group used decoys with descriptions of vacancies at Airbus, Blockchain Intelligence Group, and Goldman Sachs.

Lazarus (also known as Dark Seoul Gang, HIDDEN COBRA, and Guardians of Peace) is a cybercriminal group active since 2007. Specialists have established that the group's members are from North Korea.